CASE STUDY

The Year 2020 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

In March 2020 much of the workforce moved to remote work; AA20-133A ties the year's VPN exploitation and Office 365 misconfiguration to that shift [90]. Remote access that had been a convenience became the only way in, and VPN concentrators, Citrix gateways and load balancers that had sat unpatched since 2019 became a common front door: AA21-209A says four of the most targeted 2020 flaws affected remote work, VPN or cloud technology [84]. The year's intrusion record follows that shift closely. Governments spent the first half of 2020 warning that state and criminal actors were using COVID-19 lures and exposed remote-access gear; by the summer, the same actors were spraying passwords at vaccine researchers and chaining old VPN bugs with a brand-new domain controller flaw, Zerologon. Ransomware crews stole data before they encrypted it and published it when victims refused to pay, then, in October, turned on US hospitals during the pandemic [68]. In December, a security vendor disclosed its own breach on 8 December, and five days later disclosed that a state-sponsored actor, inside SolarWinds' network since at least September 2019, had injected a backdoor into Orion builds from February 2020; fewer than 18,000 customers were believed to have installed the tainted updates [36][37][103][104].

This study is the dated record of that year, built only from sources opened on 3 November 2026. It covers five threads: state operations named by governments and vendors, ransomware and crime, mass exploitation of vulnerabilities, supply-chain, cloud and data breaches, and the government response. SolarWinds and APT41 each have their own home study in this collection; this record gives each one paragraph and a link. Every row in the timeline carries its date, the source that supports it and an evidence grade.

Evidence grade: the advisories, directives, indictments, sanctions, regulator findings and company filings are **Confirmed** from the issuing body. Facts that rest only on press coverage (the Equifax intrusion details, Maze's shutdown, the Vastaamo extortion and verdict, the Microsoft support database record count) are **Reported**. Public proof-of-concept code for Zerologon and SMBGhost is **Demonstrated**. Where this study draws its own conclusion, it says **Inferred**.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2020, with the disclosures and court outcomes that closed 2020 events through 2024
Defining condition	The March 2020 shift to remote work; AA20-133A ties the year's VPN exploitation and Office 365 misconfiguration to it [90]
Most exploited vulnerability of 2020	Citrix CVE-2019-19781, per US Government analysis in AA21-209A; most of the top list was disclosed in the prior two years [84]
New critical flaw of the year	Netlogon CVE-2020-1472 (Zerologon), patched 11 August 2020; CISA ordered every federal domain controller patched by 21 September [79][75]
Emergency directives touching 2020	ED 20-02 (January), ED 20-03 (July), ED 20-04 (September), ED 21-01 (December) [70][72][75][39]
Largest supply-chain event	SolarWinds Orion: tainted updates released March to June 2020; about 33,000 customers notified, fewer than 18,000 believed to have installed them [104]
Hospital ransomware warning	AA20-302A, 28 October 2020: "credible information of an increased and imminent cybercrime threat" to US hospitals [68]
Schools	K-12 accounted for 57 percent of ransomware incidents reported to the MS-ISAC in August and September 2020, up from 28 percent from January to July [128]
State actors charged or sanctioned	GRU Unit 74455, PLA 54th Research Institute, APT41 members, APT39 and Rana, TsNIIKhM (Triton), Iranian actors in three cases, an RGB officer [1][13][18][22][10][23][32]
Largest takedowns	Trickbot (Microsoft court order, October 2020) and Emotet (international action, 27 January 2021) [48][67]
Framework change	ATT&CK v7 (July 2020) introduced sub-techniques; v8 (October 2020) retired PRE-ATT&CK [132][133]

Key findings

- **Old edge bugs, not zero-days, carried the year.** AA21-209A lists Citrix CVE-2019-19781, Pulse Secure CVE-2019-11510, Fortinet CVE-2018-13379, F5 CVE-2020-5902, MobileIron CVE-2020-15505 and Netlogon CVE-2020-1472 among the top routinely exploited CVEs of 2020, and says four of the most targeted hit remote work, VPN or cloud technology (Confirmed [84]). Russian, Chinese and Iranian state actors all used the same short list (Confirmed [8][16][25][5]).
- **Patching was not enough when credentials had already been taken.** CISA warned in April that actors who stole Active Directory credentials through Pulse Secure before patching kept using them after patching, and tied the activity to ransomware at hospitals and government entities (Confirmed [89]).

- **Zerologon turned an initial foothold into a domain in one step.** APT actors chained Fortinet and MobileIron flaws with CVE-2020-1472 against federal and state networks, some of which supported elections; CISA found no evidence that election data integrity was compromised (Confirmed [9]).
- **The pandemic became the lure and the target.** Gmail blocked about 18 million COVID-19 malware and phishing emails a day in April (Confirmed [47]); APT29 targeted vaccine development in Canada, the US and UK (Confirmed [5]); Strontium, Zinc and Cerium went after seven vaccine and treatment companies (Confirmed [7]); APT32 targeted the Wuhan government and China's Ministry of Emergency Management (Confirmed [21]).
- **Ransomware became a data-theft business.** Mandiant found Maze affiliates exfiltrated data before encryption in nearly all intrusions and ran a public leak site from November 2019 (Confirmed [49]). Blackbaud paid 24 Bitcoin and never verified deletion (Confirmed [56]); the Vastaamo attacker extorted psychotherapy patients one by one (Reported [59][60]).
- **Hospitals were hit at the worst moment.** UHS lost access to US IT applications from 27 September and put the pre-tax cost at about USD 67 million for 2020 (Confirmed [61]); a month later CISA, FBI and HHS warned of TrickBot, BazarLoader and Ryuk against US hospitals (Confirmed [68]), and Mandiant saw loaders lead to ransomware sometimes within 24 hours (Confirmed [69]).
- **Identity was the blast radius of the biggest breach.** After compromising networks through Orion and other vectors, the SolarWinds actor forged SAML tokens to impersonate any user on-premises or in the cloud, and CISA told victims to treat the whole identity trust store as compromised (Confirmed [105][40]).
- **Social engineering beat two-factor protections at a social platform.** Phone spear phishing of a small number of Twitter employees on 15 July gave the attackers account-support tools; 130 accounts were targeted and 45 tweeted from (Confirmed [62]). NYDFS found Twitter had no chief information security officer at the time (Confirmed [63]).
- **Governments named names.** In 2020 the US indicted GRU, PLA, Chinese contractor and Iranian actors, obtained an arrest warrant for a North Korean RGB officer, sanctioned TsNIIKhM for Triton and APT39 for its MOIS front company, and Microsoft used a court order to take Trickbot's servers (Confirmed [1][13][18][23][32][10][22][48]).

Top recommendations

1. **Treat every internet-facing remote-access device as a tier-zero asset.** Patch exploited internet-facing devices within days; CISA's 2020 emergency directives allowed one to fifteen days for Windows DNS, Netlogon and Orion [70][72][75][39] (applying that pace to edge devices is Inferred), and track them against the KEV catalog, where most of 2020's exploited edge CVEs now sit with a known ransomware flag (Confirmed [45][75]).
2. **Rotate credentials after patching an exploited edge device.** The Pulse Secure record shows a patch closes the hole but not the access already taken; reset the credentials that passed through the device (Confirmed [89]).
3. **Put phishing-resistant MFA on VPN, email and cloud administration.** Mandiant saw single-factor VPN abused in the October hospital intrusions, password spraying drove Strontium's campaigns, and the FTC found Blackbaud's MFA inadequate (Confirmed [69][6][56]).
4. **Watch the identity provider as closely as the endpoint.** Monitor token-signing certificates, federation trust changes and new service principals (Inferred); plan for full identity reconstitution, including resetting

KRBTGT twice, after a compromise of the trust store (Confirmed [40]).

5. **Plan for data theft, not only encryption.** Keep offline, encrypted backups and paper copies of the information critical operations need, as AA20-302A told hospitals, and assume a paid ransom does not buy deletion (Confirmed [68][56]).
6. **Harden the help desk and support tooling.** Verify callers who claim to be internal IT, limit who can reach account-support tools, and log their use (Confirmed [62][63]).
7. **Verify build systems, not only source code.** SolarWinds' code was injected in the build system, not the source repository; reproducible builds and build-host monitoring cover the gap (Confirmed [104]; recommendation Inferred).

Scope and method

This study covers intrusions, campaigns and disclosures dated to 2020, plus the later records (indictments, regulator findings, court outcomes) that close a 2020 event. It follows the method of the case studies collection: primary sources first, every event graded, numbers as the source states them.

Grade	Meaning in this study
Confirmed	The primary source (agency advisory or directive, court or charging document, regulator finding, company filing, the vendor's own report) was opened on 3 November 2026 and states the fact
Reported	Only a secondary source (press coverage, a researcher's publisher) was opened for the fact
Demonstrated	Public proof-of-concept code or a tester exists; it shows the flaw can be used, not that it was
Inferred	The study's own reasoning, labelled where it appears

Limits that a reader should know:

- **Pages that refused automated access.** The US Department of Justice press releases (the GRU, Equifax, APT41 and Twitter cases), the NSA's own advisory PDFs (Exim, Drovorub, the 25 CVEs), the UK ICO penalty pages and Marriott's 31 March 2020 news release did not open. Where CISA, the FBI or a company filing relays the same fact, that relay is cited and graded on what it says; otherwise the fact is Reported or left out.
- **Vendor counts are vendor counts.** Red Canary's technique ranking is one vendor's customer telemetry [134]; Microsoft's and Gmail's figures describe their own platforms [6][47].
- **Attribution is reported as the source gives it.** A vendor's "possible" link stays possible here (ESET on Lazarus and In(ter)ception [33]; Kaspersky on MosaicRegressor [19]).
- **Home studies.** SolarWinds and APT41 are summarized in a paragraph each; their home studies carry the full record.

Part 1: the year as a dated timeline

One row per event or report. The date is the event date where the source gives one, otherwise the publication date.

Date	Event	Thread	Grade	Sources
2019-12-05 to 2019-12-31	A network security group change misconfigures a Microsoft internal support case analytics database; remediated 31 Dec; Microsoft finds no malicious use and gives no record count	Data breach	Confirmed	[118]
2019-12-29	Researcher Bob Diachenko finds nearly 250 million support records across five Elasticsearch servers (his publisher's count, not Microsoft's)	Data breach	Reported	[119]
2020-01-06	APT32's first observed email to China's Ministry of Emergency Management, with a tracking link; activity runs at least to April	State	Confirmed	[21]
2020-01-10	AA20-010A: wide exploitation of Pulse Secure CVE-2019-11510 continues, months after the April 2019 patch	Exploitation	Confirmed	[88]
2020-01	AA20-010A relays media reports of REvil (Sodinokibi) ransomware deployed through unpatched Pulse Secure servers	Ransomware	Reported	[88]
2020-01-12	Cron entries show NOTROBIN installed on Citrix appliances by an actor that kills rival miners and deletes other actors' exploit artifacts	Exploitation	Confirmed	[86]
2020-01-13	CISA releases its CVE-2019-19781 check utility	Exploitation	Confirmed	[85]
2020-01-14	CISA ED 20-02 for January Patch Tuesday: CryptoAPI CVE-2020-0601 and RD Gateway CVE-2020-0609/0610/0611, patch by 29 Jan	Directive	Confirmed	[70][71]
2020-01-19 to 2020-01-24	Citrix ships permanent fixes for CVE-2019-19781 across product lines; the Citrix and FireEye IOC scanner follows on 22 Jan	Exploitation	Confirmed	[85]
2020-01-20 to 2020-03-11	APT41 global campaign against more than 75 FireEye customers via Citrix, Cisco RV320/RV325 and Zoho ManageEngine flaws	State	Confirmed	[87]
2020-01-22	Microsoft discloses the support database misconfiguration	Data breach	Confirmed	[118]
2020-01-28	Grand jury (N.D. Georgia) indicts four PLA 54th Research Institute members for the 2017 Equifax intrusion	Government	Confirmed	[13]
2020-02	North Korea's BeagleBoyz resume bank targeting (FASTCash 2.0)	State	Confirmed	[29]
2020-02-10	The Equifax indictment is announced; press accounts give the intrusion method	Government	Reported	[14]
2020-02-15	Attacker IPs using credentials stolen through Pulse Secure before patching seen as recently as this date	Exploitation	Confirmed	[89]
2020-02-20	SUNBURST injected into Orion builds	Supply chain	Confirmed	[103]
2020-03	Compromises in the SolarWinds campaign begin by at least this month	Supply chain	Confirmed	[40]

Date	Event	Thread	Grade	Sources
2020-03-10 to 2020-03-12	Microsoft ADV200005 (disable SMBv3 compression) then the CVE-2020-0796 (SMBGhost) update; publicly disclosed, not exploited, at release	Exploitation	Confirmed	[91]
2020-03-31	Marriott announces an incident involving up to about 5.2 million guests, believed accessed through an application using the login credentials of two franchise employees	Data breach	Confirmed	[114]
2020-04-08	AA20-099A (CISA and NCSC): COVID-19 phishing, malware and exploitation of rapidly deployed VPN gear	Advisory	Confirmed	[41]
2020-04-16	AA20-107A: Pulse Secure credentials reused after patching; ransomware at hospitals and government entities	Advisory	Confirmed	[89]
2020-04-16	Gmail reports blocking about 18 million COVID-19 malware and phishing emails a day	Crime	Confirmed	[47]
2020-04-22	Mandiant publishes APT32's COVID-19 espionage against Chinese government targets	State	Confirmed	[21]
2020-05-05	AA20-126A (CISA and NCSC): APT password spraying against healthcare, pharma, research and universities	Advisory	Confirmed	[42]
2020-05-12	AA20-133A: top routinely exploited vulnerabilities, with the 2020 VPN flaws and Office 365 misconfiguration after the remote-work shift	Advisory	Confirmed	[90]
2020-05-13	FBI and CISA warn COVID-19 research organizations of likely PRC targeting	Advisory	Confirmed	[15]
2020-05-13	ATT&CK creates the Ryuk software object, S0446	Framework	Confirmed	[131]
2020-05	WastedLocker in use by Evil Corp, replacing BitPaymer	Ransomware	Confirmed	[52]
2020-05-19	easyJet discloses access to about 9 million customers' email addresses and travel details and 2,208 card records	Data breach	Confirmed	[117]
2020-05-28	NSA advisory, relayed by CISA: Sandworm exploiting Exim CVE-2019-10149 since at least August 2019	State	Confirmed	[124]
2020-06	Maze posts a LockBit victim's data and speaks of a cartel, later denied	Ransomware	Reported	[50]
2020-06	The SolarWinds actor removes the SUNBURST injection code from the build environment	Supply chain	Confirmed	[103]
2020-06-02	Public SMBGhost remote code execution proof of concept published	Exploitation	Demonstrated	[92]
2020-06-05	CISA warns of functional public PoC code for CVE-2020-0796	Exploitation	Confirmed	[93]

Date	Event	Thread	Grade	Sources
2020-06-16	ICSA-20-168-01: Ripple20, 19 CVEs in the Treck TCP/IP stack; no reports of public exploitation	Exploitation	Confirmed	[101]
2020-06-17	ESET publishes Operation In(ter)ception (attacks of September to December 2019)	State	Confirmed	[33]
2020-06-23 and 2020-06-25	NCC Group and Symantec publish WastedLocker: Evil Corp attribution and at least 31 US targets	Ransomware	Confirmed	[52][53]
2020-06-29	Palo Alto discloses PAN-OS CVE-2020-2021 (SAML authentication bypass, CVSS 10.0)	Exploitation	Confirmed	[96]
2020-06-30	F5 patches BIG-IP CVE-2020-5902; exploitation within days	Exploitation	Confirmed	[94]
2020-07	The EU sanctions GRU Unit 74455 over NotPetya (as the UK statement relays it)	Government	Reported	[3]
2020-07	Emotet resurges after dormancy since February	Crime	Confirmed	[65]
2020-07-04 to 2020-07-06	Open-source reports of CVE-2020-5902 PoC and exploitation (4 Jul); CISA sees broad scanning from 6 Jul	Exploitation	Confirmed	[94]
2020-07-08	ATT&CK v7: the first non-beta Enterprise release with sub-techniques	Framework	Confirmed	[132]
2020-07-13	SAP patches RECON CVE-2020-6287; CISA issues AA20-195A the same day	Exploitation	Confirmed	[100]
2020-07-15	Twitter account takeover through phone spear phishing of employees	Crime	Confirmed	[62][63]
2020-07-16	NCSC and CSE: APT29 targets COVID-19 vaccine development with WellMess and WellMail	State	Confirmed	[5]
2020-07-16	CISA ED 20-03 for Windows DNS Server CVE-2020-1350 (SIGRed): DNS servers by 17 Jul, all Windows Servers by 24 Jul	Directive	Confirmed	[72][73][74]
2020-07-16	Blackbaud announces its ransomware incident and says bank data and SSNs were not accessed	Data breach	Confirmed	[57]
2020-07-22	Kaspersky publishes MATA, a multi-platform framework seen since April 2018, linked to Lazarus	State	Confirmed	[35]
2020-07-23	Garmin systems encrypted by a cyber attack	Ransomware (Inferred)	Confirmed	[54]
2020-07-23	AA20-205A (NSA and CISA): reduce exposure across operational technology	Advisory	Confirmed	[125]
2020-08-03	TAIDOOR RAT malware analysis, attributed with high confidence to Chinese government actors	State	Confirmed	[17]
2020-08-06	OCC assesses a USD 80 million penalty against Capital One over cloud-migration risk management	Regulator	Confirmed	[120]
2020-08-11	Microsoft releases the CVE-2020-1472 Netlogon fix, first of two phases	Exploitation	Confirmed	[79][81]

Date	Event	Thread	Grade	Sources
2020-08-11	Second APT41 indictment, as the FBI poster dates it (Qian Chuan, Fu Qiang, Jiang Lizhi, Chengdu 404)	Government	Confirmed	[18]
2020-08-13	NSA and FBI disclose Drovorub, a GRU unit 26165 Linux toolset	State	Confirmed	[4]
2020-08-19	AR20-232A: BLINDINGCAN RAT used by a DPRK-nexus group against government contractors	State	Confirmed	[30]
2020-08-26	AA20-239A: FASTCash 2.0	State	Confirmed	[29]
2020-09	CISA and MS-ISAC Ransomware Guide first ships	Defender	Confirmed	[135]
2020-09-02	CISA BOD 20-01: federal agencies must publish vulnerability disclosure policies	Directive	Confirmed	[77]
2020-09-08	Secura's public Zerologon tester repository is created	Exploitation	Demonstrated	[82]
2020-09-10	Microsoft reports Strontium, Zirconium and Phosphorus activity around the US elections	State	Confirmed	[6]
2020-09-14	AA20-258A: Chinese MSS-affiliated actors use public exploits against US agencies	State	Confirmed	[16]
2020-09-15	AA20-259A: Iran-based actor (Pioneer Kitten / UNC757) exploits VPN flaws	State	Confirmed	[25]
2020-09-15 to 2020-09-18	Three Iran-linked criminal cases, including the Heidarian indictment in New Jersey	Government	Confirmed	[23][24]
2020-09-17	Treasury designates APT39, 45 individuals and Rana Intelligence Computing Company	Government	Confirmed	[22]
2020-09-18	CISA ED 20-04: patch every domain controller for Zerologon by 21 Sep	Directive	Confirmed	[75][76]
2020-09-20 to 2020-10-17	Iranian actor scans state election websites (20 to 28 Sep), then attempts exploitation (29 Sep to 17 Oct)	State	Confirmed	[26]
2020-09-24	ATT&CK creates WellMess, S0514	Framework	Confirmed	[130]
2020-09-27	UHS IT security incident suspends access to US IT applications	Incident	Confirmed	[61]
2020-10-01	OFAC advisory on sanctions risk of facilitating ransom payments	Government	Confirmed	[55]
2020-10-01	Berserk Bear has exfiltrated data from at least two victim servers by this date	State	Confirmed	[8]
2020-10-02	ESET reports XDSpy, active since 2011	State	Confirmed	[12]
2020-10-05	Kaspersky reports MosaicRegressor, the second known public in-the-wild malicious UEFI case	State	Confirmed	[19]
2020-10-06	AA20-280A: Emotet surge, about 16,000 EINSTEIN alerts since July	Crime	Confirmed	[65]

Date	Event	Thread	Grade	Sources
2020-10-09	AA20-283A: APT actors chain VPN flaws with Zerologon	Advisory	Confirmed	[9]
2020-10-12	Microsoft obtains a court order to disable Trickbot infrastructure	Government	Confirmed	[48]
2020-10-14	NYDFS report on the Twitter hack	Regulator	Confirmed	[63]
2020-10-15	Grand jury (W.D. Pennsylvania) indicts six GRU Unit 74455 officers	Government	Confirmed	[1]
2020-10-19	US announces the GRU indictment; the UK attributes Olympic Destroyer and Tokyo 2020 reconnaissance to the GRU	Government	Confirmed	[2][3]
2020-10-20	Microsoft: 94 percent of Trickbot's critical infrastructure eliminated	Crime	Confirmed	[66]
2020-10-20	NSA advisory on 25 CVEs used by Chinese state-sponsored actors, relayed by CISA	State	Confirmed	[127]
2020-10-20	Oracle October CPU patches WebLogic CVE-2020-14882 and CVE-2020-14883	Exploitation	Confirmed	[97]
2020-10-22	AA20-296A: Berserk Bear against US state, local and aviation networks	State	Confirmed	[8]
2020-10-23	Treasury sanctions TsNIIKhM for the Triton tools	Government	Confirmed	[10]
2020-10-24	Vastaamo patients receive individual extortion emails	Crime	Reported	[59]
2020-10-27	AA20-301A on Kimsuky; ATT&CK v8 retires PRE-ATT&CK	State, Framework	Confirmed	[31][133]
2020-10-28	AA20-302A hospital ransomware warning; Mandiant KEGTAP report; Microsoft on Phosphorus conference lures	Ransomware, State	Confirmed	[68][69][27]
2020-10-29	Microsoft reports continued Netlogon exploitation; SANS sees WebLogic CVE-2020-14882 exploited against honeypots	Exploitation	Confirmed	[83][98]
2020-10-30	AA20-304A: Iranian actor obtained voter registration data; ICO fine on Marriott's Starwood incident recorded	State, Regulator	Confirmed	[26][116]
2020-11-01	Oracle out-of-band alert for CVE-2020-14750 after exploit code is published	Exploitation	Confirmed	[99]
2020-11-02	Maze announces it has closed; AA20-302A update adds Conti	Ransomware	Reported, Confirmed	[50][68]
2020-11-06	Check Point reports Pay2Key ransomware against Israeli companies	Ransomware	Confirmed	[28]
2020-11-13	Microsoft reports attacks on seven COVID-19 vaccine and treatment companies	State	Confirmed	[7]
2020-11-16	ESET attributes the WIZVERA VeraPort supply-chain attack to Lazarus	State	Confirmed	[34]

Date	Event	Thread	Grade	Sources
2020-12-01	AA20-336A: persistent APT intrusions against US think tanks	Advisory	Confirmed	[43]
2020-12-02	ESET documents Turla's Crutch	State	Confirmed	[11]
2020-12-08	FireEye discloses theft of its Red Team tools; arrest warrant issued for RGB officer Jon Chang Hyok	Supply chain, Government	Confirmed	[36][32]
2020-12-10	AA20-345A: K-12 ransomware share rises to 57 percent	Ransomware	Confirmed	[128]
2020-12-12 to 2020-12-14	SolarWinds informed (12 Dec); FireEye's SUNBURST report and CISA ED 21-01 (13 Dec); SolarWinds 8-K (14 Dec)	Supply chain	Confirmed	[103][37][39][104]
2020-12-15	Microsoft tells CrowdStrike about a reseller's Azure account making abnormal API calls months earlier	Supply chain	Confirmed	[107]
2020-12-17	AA20-352A; Microsoft notifies more than 40 customers targeted more precisely; ESET publishes SignSight	Supply chain	Confirmed	[40][106][20]
2020-12-31	Microsoft: an internal account viewed source code without permission to modify it	Supply chain	Confirmed	[108]

Part 2: state operations

Russia

The GRU indictment and the Olympics. On 15 October 2020 a federal grand jury in the Western District of Pennsylvania indicted six officers of GRU Unit 74455 (Andrienko, Detistov, Frolov, Kovalev, Ochichenko and Pliskin) for attacks on Ukrainian infrastructure, a French campaign, Georgia, NotPetya victims, the 2018 Winter Olympics and investigations into nerve-agent attacks. The charges include hacking conspiracy, wire fraud, damaging protected computers and aggravated identity theft (Confirmed [1]). At the 19 October announcement the FBI Deputy Director said NotPetya caused more than USD 2 million in damage to a Pennsylvania hospital and Olympic Destroyer took the official 2018 Winter Olympics website offline; the Pittsburgh, Atlanta and Oklahoma City field offices worked the case (Confirmed [2]). The UK said the same day, for the first time, that the GRU's GTsST unit 74455 attacked the PyeongChang Games with Olympic Destroyer while posing as North Korean and Chinese hackers, and had reconnoitred Tokyo 2020 organisers, logistics services and sponsors before the Games were postponed. It also tied the unit to BlackEnergy, Industroyer, NotPetya, BadRabbit and VPNFilter (Confirmed [3]). The UK statement mentions that the EU sanctioned the unit over NotPetya in July 2020; the EU's own texts were not opened (Reported [3]). ATT&CK's Sandworm Team (G0034) page lists the operations in the indictment and the Exim exploitation, with no campaign object for 2019 or 2020 (Confirmed [126]).

Sandworm and Exim. In May the NSA warned, in an advisory CISA relayed, that Sandworm had exploited unpatched Exim mail servers through CVE-2019-10149 since at least August 2019, two months after the patch shipped (Confirmed [124]).

Drovorub. On 13 August the NSA and FBI disclosed Drovorub, a Linux toolset made of an implant, a kernel-module rootkit, a file transfer and port forwarding tool and a C2 server, deployed by the GRU 85th

GTsSS, unit 26165, which industry tracks as APT28 (Confirmed [4]). ATT&CK added it as S0502 on 25 August, associated with APT28 (G0007) (Confirmed [46]).

APT29 and the vaccine. On 16 July the UK NCSC and Canada's CSE, with NSA agreement and CISA endorsement, said APT29 targeted COVID-19 vaccine development in Canada, the US and the UK throughout 2020. The group scanned for vulnerable servers and used public exploits for Citrix CVE-2019-19781, Pulse Secure CVE-2019-11510, Fortinet CVE-2018-13379 and Zimbra CVE-2019-9670, plus credential spear phishing, then deployed WellMess and WellMail (Confirmed [5]). ATT&CK created WellMess (S0514) on 24 September 2020 (Confirmed [130]).

Strontium and the elections. Microsoft said on 10 September that Strontium attacked more than 200 organisations, including political campaigns, parties and consultants, between September 2019 and September 2020. It had moved from spear phishing to brute force and password spray run through more than 1,000 rotating IP addresses, many of them Tor (Confirmed [6]). In November Microsoft named Strontium again among three actors targeting seven vaccine and treatment companies in Canada, France, India, South Korea and the US, in its case by password spray and brute force (Confirmed [7]).

Berserk Bear against state and local government. AA20-296A (22 October) said a Russian state-sponsored actor, which the advisory calls Berserk Bear, Energetic Bear or Dragonfly (G0035), targeted dozens of US state, local, tribal and territorial networks and aviation networks since at least September 2020, and had exfiltrated data from at least two victim servers by 1 October. It exploited Exim CVE-2019-10149, Fortinet CVE-2018-13379, Netlogon CVE-2020-1472, Citrix CVE-2019-19781 and Exchange CVE-2020-0688 (Confirmed [8]).

Triton. On 23 October Treasury sanctioned the Russian research institute TsNIIKhM under CAATSA section 224 for building the Triton tools (also called TRISIS and HatMan) used against a Middle East petrochemical facility in August 2017 (Confirmed [10]).

Turla's Crutch. ESET documented Crutch on 2 December: a Turla backdoor and document stealer used from 2015 to at least early 2020 that exfiltrated to Dropbox, found at a ministry of foreign affairs in an EU country (Confirmed [11]).

SolarWinds (summary; home study SolarWinds and SUNBURST, 2019 to 2021). On 8 December FireEye said a highly sophisticated state-sponsored adversary had stolen its Red Team tools, which held no zero-days, and released hundreds of countermeasures (Confirmed [36]). On 13 December it disclosed UNC2452 trojanizing SolarWinds Orion updates with SUNBURST; the updates were signed from March to May 2020, and a May 2022 note merges UNC2452 into APT29 (Confirmed [37]). SolarWinds later put the first suspicious internal activity in September 2019, the injection into builds from 20 February 2020 and the removal of the code in June 2020 (Confirmed [103]). CISA issued ED 21-01 on 13 December and AA20-352A on 17 December; its 15 April 2021 revision attributes the activity to the SVR (Confirmed [39][40]). The supply-chain and cloud consequences are summarized in Part 5.

China

Equifax. On 28 January 2020 a grand jury in the Northern District of Georgia indicted Wang Qian, Xu Ke, Liu Lei and Wu Zhiyong, members of the PLA 54th Research Institute, for the 2017 Equifax intrusion (13 May to 30 July 2017). The data taken includes names, birth dates and Social Security numbers of about 145 million Americans, driver's licence numbers for at least 10 million, and personal information of nearly a million UK and Canadian citizens (Confirmed [13]). A press account of the 10 February announcement describes entry through an Apache Struts flaw in the dispute portal, about 9,000 database queries, archives split into 600 MB segments, exfiltration over HTTP through about 34 servers in 20 countries, and deleted logs (Reported [14]). The DOJ release did not open; the link to Struts CVE-2017-5638 is Inferred. ATT&CK has no group object for the 54th Research Institute in the library data, so it is left unmapped.

COVID-19 research and MSS-affiliated actors. On 13 May the FBI and CISA warned COVID-19 research organizations of likely targeting and network compromise by the PRC (Confirmed [15]). AA20-258A (14 September) said Chinese MSS-affiliated actors use public information and off-the-shelf exploits against US government agencies, naming Pulse Secure CVE-2019-11510, Citrix CVE-2019-19781, Exchange CVE-2020-0688 (used to collect email) and F5 CVE-2020-5902, with Cobalt Strike, China Chopper and Mimikatz (Confirmed [16]). The advisory also prints PRE-ATT&CK ids that no longer exist in ATT&CK v20.0; Part 8 leaves them out. On 20 October the NSA published 25 CVEs exploited or scanned for by Chinese state-sponsored actors, relayed by CISA; the NSA PDF did not open, so the list is not reproduced here (Confirmed for the advisory's existence [127]).

TAIDOOR. On 3 August CISA, the FBI and DoD published a malware analysis of the TAIDOOR RAT and attributed it with high confidence to Chinese government actors (S0011) (Confirmed [17]).

Zirconium and the elections. Microsoft said Zirconium (G0128, which the library also lists as APT31) made thousands of attacks from March to September 2020 with nearly 150 compromises, targeting people tied to the Biden campaign (indirectly and unsuccessfully), a former Trump administration figure and international-affairs academics, using web beacons (Confirmed [6]).

MosaicRegressor. Kaspersky found rogue UEFI firmware that dropped the MosaicRegressor framework on diplomats and NGO members in Africa, Asia and Europe whose activity related to North Korea. It assessed a Chinese-speaking actor, possibly linked to users of Winnti, and called it the second known public case of malicious UEFI firmware in the wild (Confirmed [19]).

APT41 (summary; home study APT41: the public record). The FBI poster records indictments of 15 August 2019 (Zhang Haoran, Tan Dailin) and 11 August 2020 (Qian Chuan, Fu Qiang, Jiang Lizhi and Chengdu 404), alleging supply-chain attacks on hundreds of companies (Confirmed [18]). FireEye's 25 March 2020 report described a global campaign from 20 January to 11 March against more than 75 of its customers: Citrix exploitation from 20 January, Cisco RV320/RV325 (CVE-2019-1652 and CVE-2019-1653) from 21 February and Zoho ManageEngine CVE-2020-10189 from 8 March, followed by Cobalt Strike BEACON and Meterpreter (Confirmed [87]). APT41 (G0096) is mapped in Part 8 only for the techniques of that report.

Vietnam and Southeast Asia

APT32 and Wuhan. Mandiant said APT32 targeted China's Ministry of Emergency Management and the Wuhan government from at least January to April 2020. The first email, on 6 January, carried a tracking link; later lures were likely COVID-themed attachments delivering the METALJACK loader (Confirmed [21]). APT32 (G0050).

Operation SignSight. ESET found two trojanized installers on the website of the Vietnam Government Certification Authority (ca.gov.vn). It found them in early December 2020 and believed they were no longer served by the end of August 2020 (Confirmed [20]). ESET's post names no group in the claims this study carries, so no group is mapped.

Iran

APT39 and Rana. On 17 September Treasury's OFAC designated APT39, 45 individuals and the MOIS front company Rana Intelligence Computing Company for malware campaigns against dissidents, journalists and the travel sector; the FBI released details of eight malware sets the same day (Confirmed [22]). APT39 (G0087).

Three criminal cases in one week. The FBI summarized three Iran-linked cases of 15 to 18 September: a Massachusetts indictment for defacements (Mohammadzadeh and Abusrour) after the January 2020 killing of the IRGC-QF commander; New Jersey charges against Heidarian and Farhadi for the theft of hundreds of terabytes; and Virginia charges against three IRGC-linked actors with more than 1,800 target accounts, including aerospace and satellite firms (Confirmed [23]). The Heidarian indictment was returned on 15 September with charges including computer fraud conspiracy, unauthorized access, wire fraud conspiracy, access device fraud and aggravated identity theft (Confirmed [24]).

Pioneer Kitten. AA20-259A (15 September) described an Iran-based actor that CISA correlates with Pioneer Kitten and UNC757 (the library's Fox Kitten, G0117). It mass-scanned with Nmap and exploited Pulse Secure CVE-2019-11510 and CVE-2019-11539, Citrix CVE-2019-19781 (its primary access vector) and F5 CVE-2020-5902 against US federal and private sectors, held access for months, and used the ChunkyTuna, Tiny and China Chopper web shells with FRP, Chisel and ngrok tunnels (Confirmed [25]).

The election websites. AA20-304A (30 October) said an Iranian APT actor scanned state election websites with Acunetix from 20 to 28 September, attempted exploitation from 29 September to 17 October with directory traversal, SQL injection and web shell uploads, obtained voter registration data in at least one state, and was responsible for voter-intimidation emails and a propaganda video in mid-October (Confirmed [26]).

Phosphorus. Microsoft said Phosphorus (Magic Hound, G0059, which the library also lists as Phosphorus and Charming Kitten) kept attacking personal accounts of people tied to the Trump campaign, and that a court order let it take 25 more Phosphorus domains, 155 in total (Confirmed [6]). In October it reported spoofed Munich Security Conference and T20 invitations sent to more than 100 high-profile people, several of whom were compromised, including former ambassadors (Confirmed [27]).

Pay2Key. Check Point reported Pay2Key ransomware hitting Israeli companies in November, with access presumably over RDP, spread by psexec within an hour, and ransoms of 7 to 9 BTC; the post makes no attribution (Confirmed [28]). Pay2Key (S0556).

North Korea

FASTCash 2.0. AA20-239A (26 August) said that since February 2020 North Korea's BeagleBoyz, overlapping Lazarus, APT38 and Bluenoroff, had resumed targeting banks for fraudulent transfers and ATM cash-outs, attempting to steal nearly USD 2 billion since 2015. Tools named include ECCENTRICBANDWAGON, ELECTRICFISH, HOPLIGHT, VIVACIOUSGIFT, CROWDEDFLOUNDER and COPPERHEDGE (Confirmed [29]). APT38 (G0082), HOPLIGHT (S0376), ECCENTRICBANDWAGON (S0593).

BLINDINGCAN. AR20-232A (19 August) described the BLINDINGCAN RAT, used by a DPRK-nexus group against government contractors early in 2020 with defense-contractor job lures and C2 on compromised infrastructure in several countries (Confirmed [30]). BLINDINGCAN (S0520).

Kimsuky. AA20-301A (27 October, CISA, FBI and CNMF) described Kimsuky (G0094), assessed active since 2012 and tasked with global intelligence collection through spear phishing and watering holes against South Korea, Japan and the US. The advisory names BabyShark, GREASE and MECHANICAL, calls spearphishing attachments the most observed initial access, and lists 27 technique ids (Confirmed [31]).

Operation In(ter)ception and Dream Job. ESET's June report covered September to December 2019 attacks on European and Middle Eastern aerospace and military firms through fake LinkedIn HR profiles posing as Collins Aerospace and General Dynamics, with signed malware and one business email compromise attempt. ESET called the Lazarus link only possible (Confirmed [33]). The library maps this activity to the campaign Operation Dream Job (C0022), active September 2019 to August 2020 [102].

WIZVERA VeraPort. In November ESET attributed with strong confidence to Lazarus a South Korean supply-chain attack that abused WIZVERA VeraPort and code-signing certificates stolen from two companies, continuing what KrCERT called Operation Bookcodes (Confirmed [34]).

MATA. Kaspersky described MATA, a Windows, Linux and macOS malware framework seen since April 2018 and linked to Lazarus through Manuscrypt filename and configuration overlaps (Confirmed [35]). MATA has no software object in the library data and is not linked.

The RGB officer. A federal arrest warrant was issued in the Central District of California on 8 December 2020 for RGB officer Jon Chang Hyok (part of the Lazarus and APT38 conspiracy) on wire and bank fraud conspiracy and computer fraud conspiracy; the charges were unsealed in February 2021 (Confirmed [32]).

Unattributed or regional

XDSpy. ESET reported XDSpy on 2 October, a previously undocumented espionage group active since 2011 against governments and companies in Belarus, Moldova, Russia, Serbia and Ukraine; ESET does not attribute it or call it state-sponsored (Confirmed [12]).

Operation Spalax. ESET's January 2021 report covers 2020 attacks on Colombian government, energy and metallurgical companies with commodity RATs, at least 24 C2 IP addresses in the second half of 2020 and dynamic DNS; attribution was difficult (Confirmed [44]). The library maps it to Operation Spalax (C0005) [102].

Cross-actor advisories. CISA and NCSC reported APT and criminal use of COVID-19 themes and exploitation of teleworking VPN exposure in April (AA20-099A) and APT password spraying against healthcare in the UK, US and elsewhere in May (AA20-126A) (Confirmed [41][42]). In December, AA20-336A warned of persistent APT intrusions against US think tanks focused on international affairs and national security (Confirmed [43]).

Part 3: ransomware and crime

The pandemic lure wave

AA20-099A (8 April, CISA and NCSC) described criminal and state actors using COVID-19 themes in phishing, SMS phishing and malware (Agent Tesla, TrickBot, Get2 and GraceWire, CovidLock) and coronavirus-themed domains, and exploiting rapidly deployed VPN and remote-access gear from Citrix, Pulse Secure, Fortinet and Palo Alto. It cites a 127 percent rise in exposed RDP endpoints (Confirmed [41]). A week later Google said Gmail had blocked about 18 million COVID-19 related malware and phishing emails a day in the prior week, plus more than 240 million COVID-related spam messages daily (Confirmed [47]). Microsoft later said its Office 365 ATP data showed Trickbot was the most prolific malware operation using COVID-19 lures (Confirmed [48]).

Maze and double extortion

Mandiant's Maze report describes deployments since at least May 2019, theft plus encryption with a public leak site from November 2019, and an affiliate model in which data was exfiltrated before encryption in nearly all intrusions. Initial access came through macro phishing, RDP support accounts and Citrix accounts with weak passwords; the tools included Cobalt Strike BEACON, Mimikatz, ProcDump, BloodHound, AdFind, ngrok, tscon, WinSCP, 7-Zip, PsExec and WMIC; one affiliate group was linked to FIN6 (Confirmed [49]). Press coverage reports that Maze posted a LockBit victim's data in June 2020 and spoke of a cartel it later denied, announced on 2 November that the project was closed after it stopped encrypting new victims in mid-September, and that some affiliates moved to Egregor; named victims include Southwire, the City of Pensacola, Canon, LG Electronics and Xerox (Reported [50]). By late 2020 the leak-site model was the default for big-game crews, which is why the Blackbaud and Vastaamo cases turn on stolen data rather than encryption (Inferred [49]). Maze (S0449), Egregor (S0554), FIN6 (G0037).

Evil Corp, WastedLocker and Garmin

Treasury sanctioned Evil Corp, 17 individuals and seven entities on 5 December 2019, alongside DOJ charges against Maksim Yakubets and Igor Turashev and a USD 5 million reward for Yakubets; it said Evil Corp earned at least USD 100 million with Dridex and that Yakubets worked for the FSB as of 2017 (Confirmed [51]). Six months later NCC Group and Fox-IT assessed with high confidence that WastedLocker, in use since May 2020, was an Evil Corp locker that replaced BitPaymer after the indictments and sanctions. SocGholish fake updates dropped a custom Cobalt Strike loader; a UAC bypass used a winmm.dll hijack with the payload in an NTFS alternate data stream; shadow copies were deleted and Defender disabled; little information stealing was observed (Confirmed [52]). Symantec counted at least 31 targeted US organisations, eight of them Fortune 500 companies, with SocGholish served from at least 150 compromised sites, including dozens of US newspaper sites (Confirmed [53]). Indrik Spider (G0119), WastedLocker (S0612), SocGholish (S1124), BitPaymer (S0570), Dridex (S0384).

Garmin disclosed that a cyber attack encrypted some of its systems on 23 July 2020, interrupting website functions, customer support, customer-facing apps and company communications, with no indication that customer or Garmin Pay data was accessed. Garmin names neither the ransomware family nor the actor (Confirmed [54]); this study does not either. On 1 October OFAC warned that facilitating ransom payments carries sanctions exposure and that reporting and cooperation is a significant mitigating factor (Confirmed [55]).

Blackbaud

The FTC found the Blackbaud attacker went undetected for three months, moved across hosted environments through existing vulnerabilities, used local administrator accounts and created new ones. MFA was not adequately implemented, passwords were weak or identical, and Blackbaud paid 24 Bitcoin (about USD 250,000) without ever verifying the data was deleted (Confirmed [56]). The SEC found that Blackbaud's 16 July 2020 announcement said bank data and Social Security numbers were not accessed while staff soon knew otherwise, that its August 2020 10-Q called the risk hypothetical, and that more than 13,000 customers were affected; it imposed a USD 3 million penalty on 9 March 2023 (Confirmed [57]). The FTC finalized its order in May 2024, requiring deletion of unneeded data, a security program, a retention schedule and notice of future breaches (Confirmed [58]).

Vastaamo

Patients of the Finnish psychotherapy provider Vastaamo received individual emails in October 2020 demanding 200 euros in Bitcoin within 24 hours, or 500 euros within 48 hours, under threat of publishing their therapy records; police advised them not to pay (Reported [59]). Finnish public broadcaster coverage of the verdict says the database was stolen in autumn 2018 with about 33,000 victims, that the attacker demanded 370,000 euros from Vastaamo and published records on Tor when it refused, and that on 30 April 2024 the Western Uusimaa District Court convicted Aleksanteri Kivimaki on all counts, including almost 9,600 aggravated invasions of privacy and more than 21,300 attempted aggravated extortions, with a sentence of 6 years and 3 months (Reported [60]). The court record and any appeal were not opened.

Universal Health Services

UHS's 2020 annual report says an IT security incident early on 27 September 2020 suspended user access to its US IT applications, which were restored on a rolling basis in October. Ambulances and elective procedures were diverted, billing was delayed into December, and the pre-tax impact was about USD 67 million for 2020; UHS found no evidence that patient or employee data was accessed (Confirmed [61]). The filing does not name a ransomware family, and this study does not.

Twitter, 15 July 2020

Twitter said phone spear phishing of a small number of employees on 15 July led the attackers to staff with access to account-support tools. They targeted 130 accounts, tweeted from 45, accessed 36 DM inboxes and downloaded the Twitter Data archive for 7, getting through two-factor protections (Confirmed [62]). NYDFS found that callers posed as Twitter IT staff and four employees gave up credentials; the hijacked accounts included Obama, Bezos, Musk and DFS-regulated cryptocurrency firms; the bitcoin scam took more than USD 118,000 while Coinbase, Square, Gemini and Bitstamp blocked transfers; Twitter had no CISO at the time; and DFS proposed that the largest platforms be designated systemically important (Confirmed [63]). On 21 July 2021 UK citizen Joseph O'Connor, 22, was arrested in Estepona, Spain, at US request on a Northern District of California complaint for the hack (Confirmed [64]).

TrickBot and Emotet

AA20-280A (6 October) said Emotet resurged in July after dormancy from February, with about 16,000 EINSTEIN alerts since July; it worked as a downloader or dropper, delivering TrickBot and QakBot in September, and used thread hijacking and password-protected archives (Confirmed [65]). On 12 October Microsoft obtained an order from the Eastern District of Virginia to disable Trickbot's C2, with FS-ISAC as co-plaintiff and ESET, Lumen's Black Lotus Labs, NTT and Symantec assisting. It was the Digital Crimes Unit's first use of copyright claims; Trickbot had infected more than a million devices since late 2016 and delivered Ryuk, and Microsoft framed the action around the US elections (Confirmed [48]). By 20 October Microsoft said 94 percent of Trickbot's critical infrastructure was eliminated: 120 of 128 servers down and all but one of 59 replacement servers disabled (Confirmed [66]). The epilogue came on 27 January 2021, when authorities of the Netherlands, Germany, the US, the UK, France, Lithuania, Canada and Ukraine, coordinated by Europol and Eurojust, took control of Emotet's infrastructure of several hundred servers; Eurojust described Emotet as a primary door opener for TrickBot and Ryuk that used COVID-19 lures (Confirmed [67]). TrickBot (S0266), Emotet (S0367), QakBot (S0650).

The October hospital wave

AA20-302A (28 October, CISA, FBI and HHS) reported credible information of an increased and imminent cybercrime threat to US hospitals. It described TrickBot delivering Ryuk and, in the 2 November update, Conti; BazarLoader and BazarBackdoor delivered through Google Docs link lures; Anchor_DNS tunnelling over DNS with the single-byte XOR key 0xB9; Mimikatz, Cobalt Strike, Empire and BloodHound; lateral movement over PowerShell, WMI, WinRM and RDP; and shadow-copy deletion with vssadmin. The agencies did not recommend paying ransoms and told hospitals to print and store hard copies of information needed for critical patient care (Confirmed [68]). Mandiant's report the same day found the KEGTAP, SINGLEMALT and WINEKEY loaders (the Bazar family) led to ransomware sometimes within 24 hours against hospitals, retirement communities and medical centres, in most cases by UNC1878 deploying Ryuk. Payloads were hosted on Google Drive, Basecamp, Slack and Trello; persistence used scheduled tasks, Startup folder LNK files, BITS and Winlogon Userinit; single-factor VPN was abused; Kerberoasting and ntds.dit export followed. Mandiant recommended VPN MFA and Zerologon patching (Confirmed [69]). The library lists UNC1878 and FIN12 as aliases of Wizard Spider (G0102) [102]. Ryuk (S0446), Bazar (S0534), Anchor (S0504), Conti (S0575).

Schools

AA20-345A (10 December, FBI, CISA and MS-ISAC) said K-12 schools accounted for 57 percent of reported ransomware incidents in August and September 2020, up from 28 percent from January to July, naming Ryuk, Maze, Nefilim, AKO and Sodinokibi/REvil (Confirmed [128]). The figure counts incidents reported to the MS-ISAC, not all incidents. REvil (S0496).

Part 4: vulnerabilities and mass exploitation

The emergency directives of 2020

CISA issued three emergency directives on 2020 vulnerabilities, one on SolarWinds, and a binding operational directive on vulnerability disclosure:

Directive	Issued	Subject	Deadline	Sources
ED 20-02	14 Jan 2020	CryptoAPI CVE-2020-0601; RD Gateway CVE-2020-0609, 0610, 0611	Patch by 5:00 pm EST 29 Jan; initial report 17 Jan	[70][71]
ED 20-03	16 Jul 2020	Windows DNS Server CVE-2020-1350 (SIGRed)	DNS-role servers by 2:00 pm EDT 17 Jul; all Windows Servers by 24 Jul	[72][73][74]
BOD 20-01	2 Sep 2020	Vulnerability disclosure policies	Policy within 180 days (1 Mar 2021); all internet-accessible systems in scope by 2 Sep 2022	[77]
ED 20-04	18 Sep 2020	Netlogon CVE-2020-1472 (Zerologon)	Every domain controller by 11:59 pm EDT 21 Sep; report by 23 Sep	[75][76]
ED 21-01	13 Dec 2020	SolarWinds Orion 2019.4 through 2020.2.1 HF1	Disconnect or power down; report by noon 14 Dec; supplemental guidance 18 Dec, 30 Dec 2020, 6 Jan 2021 and v4 of 22 Apr 2021; the directive is now closed	[39][38]

For SIGRed, CISA said it was unaware of active exploitation but judged that the patch could be reverse engineered quickly (Confirmed [72]). For Zerologon, its rationale included exploit code available in the wild (Confirmed [75]). The ED 20-02, 20-03 and 20-04 pages now say the directives are closed with their required actions moved into BOD 22-01 (Confirmed [70][74][75]). BOD 22-01 created the KEV catalog on 3 November 2021; its page now shows it superseded by BOD 26-04, "Prioritizing Security Updates Based on Risk" (Confirmed, a current-state fact [78]).

Zerologon (CVE-2020-1472)

Microsoft released the fix on 11 August 2020 for a Netlogon (MS-NRPC) elevation of privilege that let an unauthenticated attacker obtain domain administrator access, in a phased two-part rollout (Confirmed [79]). NVD published the record on 17 August with a CVSS 3.1 score of 10.0 (Microsoft as CNA scored 5.5) and the weakness NVD-CWE-noinfo (Confirmed [80]). KB4557222 set the initial deployment phase from 11 August 2020 and the enforcement phase from 9 February 2021, when domain controllers enforce secure RPC regardless of the registry key (Confirmed [81]). Secura's public tester repository was created on 8 September (Demonstrated [82]). AA20-283A (9 October, revised 24 October) then reported APT actors chaining Fortinet CVE-2018-13379 and, less often, MobileIron CVE-2020-15505 for initial access with CVE-2020-1472 for privilege escalation, using Mimikatz and CrackMapExec (Confirmed [9]). On 29 October Microsoft reported continued exploitation and urged updates and enforcement mode (Confirmed [83]). Mandiant's October hospital-wave report recommended Zerologon patching (Confirmed [69]), and AA21-209A lists it among the CVEs routinely exploited in 2020 (Confirmed [84]).

Citrix CVE-2019-19781 carried into 2020

Disclosed on 17 December 2019 with mitigations only, the Citrix flaw received permanent fixes from 19 to 24 January 2020; CISA released a check utility on 13 January and the Citrix and FireEye IOC scanner followed on 22 January. NVD lists CWE-22 and CVSS 9.8 (Confirmed [85]). FireEye reported on 15 January that an unnamed actor exploiting it killed competing miners and installed NOTROBIN, which deleted other actors' exploit artifacts unless they carried a hardcoded key; it found nearly 100 keys (Confirmed [86]). The same flaw was APT41's entry from 20 January (Confirmed [87]), Pioneer Kitten's primary access vector (Confirmed [25]), and the most exploited CVE of the year (Confirmed [84]).

Pulse Secure CVE-2019-11510 carried into 2020

Patched on 24 April 2019, the flaw was still widely exploited in January 2020 (Confirmed [88]). AA20-107A found that credentials stolen before patching stayed in use after patching, with attacker IPs seen as recently as 15 February 2020 and ransomware at hospitals and US government entities (Confirmed [89]). AA20-133A named it and Citrix CVE-2019-19781 as VPN flaws exploited in 2020 (Confirmed [90]).

SMBGhost (CVE-2020-0796)

Microsoft published ADV200005 on 10 March (disable SMBv3 compression, no patch yet) and the update on 12 March; the flaw was marked publicly disclosed, not exploited, at release (Confirmed [91]). A public remote code execution proof of concept appeared on 2 June (Demonstrated [92]), and on 5 June CISA warned of functional public PoC code and told organizations to block SMB ports from the internet (Confirmed [93]). KEV added it on 10 February 2022 with known ransomware use (Confirmed [45]).

F5 BIG-IP CVE-2020-5902

F5 patched on 30 June. Open-source reports of PoC code and exploitation came on 4 July, CISA saw broad scanning from 6 July and confirmed compromises within days of the patch (Confirmed [94]). NVD published the record on 1 July with CWE-22 and CVSS 9.8 (Confirmed [95]).

Palo Alto PAN-OS CVE-2020-2021

Published on 29 June with CVSS 10.0, the flaw was a SAML authentication bypass when "Validate Identity Provider Certificate" was disabled, affecting GlobalProtect, Prisma Access, captive portal and the management interface on PAN-OS 9.1 before 9.1.3, 9.0 before 9.0.9, 8.1 before 8.1.15 and all 8.0 releases. Palo Alto was unaware of malicious attempts at publication; NVD lists CWE-347 (Confirmed [96]). KEV added it on 25 March 2022 with known ransomware use (Confirmed [45]).

Oracle WebLogic CVE-2020-14882 and CVE-2020-14750

The October 2020 Critical Patch Update (20 October) fixed CVE-2020-14882 and CVE-2020-14883, credited to voidfyoo of Chaitin Security Research Lab (Confirmed [97]). SANS saw CVE-2020-14882 exploited against honeypots about a week later, after PoCs were published (Confirmed [98]). Oracle issued an out-of-band alert for the related CVE-2020-14750 on 1 November because exploit code had been published; NVD scores it 9.8 (Confirmed [99]).

SAP RECON (CVE-2020-6287)

AA20-195A came out on 13 July, the day SAP patched: missing authentication in the NetWeaver AS Java 7.30 to 7.50 LM Configuration Wizard let remote unauthenticated attackers create high-privileged users and run OS commands (SAP Notes 2934135 and 2939665). CISA was unaware of active exploitation at release. NVD lists CWE-306 and CVSS 10.0; KEV added it on 3 November 2021 (Confirmed [100]).

Ripple20 (Treck TCP/IP)

ICSA-20-168-01 (16 June) covered 19 CVEs, CVE-2020-11896 to CVE-2020-11914, in the Treck TCP/IP stack, reported by Shlomi Oberman and Moshe Kol of JSOF. CVE-2020-11896 and CVE-2020-11897 scored 10.0; the fix is Treck 6.0.1.67 or later; there were no reports of public exploitation (Confirmed [101]). CVE-2020-11896 is not in KEV (Confirmed [45]).

The year in retrospect

AA21-209A (28 July 2021; CISA, ACSC, NCSC and FBI) lists the top CVEs routinely exploited in 2020: Citrix CVE-2019-19781, Pulse CVE-2019-11510, Fortinet CVE-2018-13379, F5 CVE-2020-5902, MobileIron CVE-2020-15505, Microsoft Exchange CVE-2020-0688, Atlassian Confluence CVE-2019-3396, Microsoft Office CVE-2017-11882, Atlassian Crowd CVE-2019-11580, Drupal CVE-2018-7600, Telerik CVE-2019-18935, SharePoint CVE-2019-0604, Windows BITS CVE-2020-0787 and Netlogon CVE-2020-1472. A majority were disclosed during the past two years (Confirmed [84]). The KEV catalog's first load on 3 November 2021 carries 13 of the 14 (Windows BITS CVE-2020-0787 was added on 28 January 2022) and flags known ransomware campaign use for every one of them except MobileIron CVE-2020-15505 (Confirmed [45]).

CVE	Product	NVD weakness	KEV date added	KEV ransomware use	Sources
CVE-2019-19781	Citrix ADC, Gateway, SD-WAN WANOP	CWE-22	2021-11-03	Known	[85][45]
CVE-2019-11510	Pulse Connect Secure	CWE-22	2021-11-03	Known	[45]
CVE-2019-11539	Pulse Connect Secure	CWE-78	2021-11-03	Known	[45]
CVE-2018-13379	Fortinet FortiOS SSL VPN	CWE-22	2021-11-03	Known	[45]
CVE-2020-5902	F5 BIG-IP TMUI	CWE-22	2021-11-03	Known	[95][45]
CVE-2020-15505	MobileIron	CWE-706	2021-11-03	Unknown	[45]
CVE-2020-0688	Microsoft Exchange	CWE-287	2021-11-03	Known	[45]
CVE-2019-3396	Atlassian Confluence	CWE-22	2021-11-03	Known	[45]
CVE-2020-1472	Netlogon (Zerologon)	NVD-CWE-noinfo	2021-11-03	Known	[80][45]
CVE-2020-1350	Windows DNS Server (SIGRed)	CWE-20	2021-11-03	Unknown	[45]
CVE-2020-0601	Windows CryptoAPI	CWE-295	2021-11-03	Unknown	[45]
CVE-2020-0796	SMBv3 (SMBGhost)	CWE-119	2022-02-10	Known	[45][102]
CVE-2020-0787	Windows BITS	not cited	2022-01-28	Known	[45]
CVE-2020-2021	PAN-OS SAML	CWE-347	2022-03-25	Known	[96][45]
CVE-2020-6287	SAP NetWeaver AS Java (RECON)	CWE-306	2021-11-03	Unknown	[100][45]
CVE-2020-14882, CVE-2020-14750	Oracle WebLogic	not cited	2021-11-03	Unknown	[45]
CVE-2019-10149	Exim	CWE-78	2022-01-10	Unknown	[45]
CVE-2019-9670	Zimbra	CWE-611	2022-01-10	Unknown	[45]
CVE-2017-5638	Apache Struts (Equifax link Inferred)	CWE-755	2021-11-03	Known	[45]
CVE-2020-11896	Treck TCP/IP (Ripple20)	not cited	not in KEV	not applicable	[45]

Part 5: supply chain, cloud and data breaches

SolarWinds in context (summary; home study SolarWinds and SUNBURST, 2019 to 2021)

SolarWinds' 14 December 8-K said the tainted Orion updates were released from March to June 2020 through a compromise of the Orion build system, not the source repository; about 33,000 maintenance customers were notified on 13 December, fewer than 18,000 were believed to have installed affected versions, and SolarWinds' Office 365 email was also compromised (Confirmed [104]). FireEye's report described a trojanized, signed `SolarWinds.Orion.Core.BusinessLayer.dll` that stayed dormant up to two weeks, used DNS C2 through `avsvmcloud[.]com` subdomains with CNAME responses, mimicked Orion Improvement Program traffic, and delivered Cobalt Strike BEACON through the memory-only TEARDROP dropper (Confirmed [37]). Microsoft's guidance said the actor then reached global administrator rights or the SAML token-signing certificate and forged tokens to impersonate any user (Confirmed [105]). AA20-352A added vectors beyond Orion: SAML abuse, password guessing and spraying, poorly secured administrator credentials through external remote services, and a Duo MFA bypass (Confirmed [40]). Microsoft notified more than 40 customers targeted more precisely, about 80 percent in the US, with victims in Canada, Mexico, Belgium, Spain, the UK, Israel and the UAE (Confirmed [106]). Microsoft's own investigation found one internal account viewed source code in a number of repositories without permission to modify it (Confirmed [108]).

The follow-on record runs into 2021 and beyond. CrowdStrike said Microsoft contacted it on 15 December 2020 about a reseller's Azure account making abnormal Microsoft cloud API calls for 17 hours months earlier; an attempt to read email failed, and CrowdStrike did not name the actor (Confirmed [107]). The Cyber Unified Coordination Group (FBI, CISA, ODNI and NSA) said on 5 January 2021 the actor was likely Russian, that the effort was intelligence gathering, and that of about 18,000 affected Orion customers a much smaller number saw follow-on activity, including fewer than ten US government agencies (Confirmed [109]). Mimecast said Microsoft told it a Mimecast-issued certificate for Microsoft 365 Exchange Web Services connections was compromised (Confirmed [110]) and later that the same actor entered part of its production grid through SolarWinds and accessed certificates, connection data, encrypted or hashed credentials and limited source code, with no evidence customer email was accessed (Confirmed [111]). The White House formally named the SVR on 15 April 2021, and said the actor could spy on or disrupt more than 16,000 systems worldwide (Confirmed [112]). On 22 October 2024 the SEC charged Unisys (USD 4 million), Avaya (USD 1 million), Check Point (USD 995,000) and Mimecast (USD 990,000) over misleading SolarWinds-related disclosures (Confirmed [113]).

Marriott

Marriott's Q1 2020 10-Q records the 31 March announcement of an incident involving up to about 5.2 million guests, believed accessed through an application using the credentials of two franchise employees, with two lawsuits filed (Confirmed [114]). The FTC's October 2024 action says this third Marriott breach went undetected from September 2018 to February 2020 and exposed 5.2 million guest records, 1.8 million of them Americans', including names, addresses, emails, phone numbers, month and day of birth and loyalty information; the proposed order requires a 20-year security program (Confirmed [115]). Marriott's Q3 2020 10-Q records the ICO's final GBP 18.4 million fine over the earlier Starwood incident, not the 2020 one, and that Marriott would not appeal (Confirmed [116]).

easyJet

easyJet's 19 May RNS said a highly sophisticated source accessed the email addresses and travel details of about 9 million customers and card details for 2,208; it notified the NCSC and the ICO and said customers would be told by 26 May. It disclosed neither method nor intrusion dates (Confirmed [117]), so no technique is mapped.

Microsoft's support database

Microsoft said a 5 December 2019 network security group change misconfigured an internal support case analytics database, remediated on 31 December; it found no malicious use, said some records stayed unredacted where personal data was in a non-standard format, said it was not a commercial cloud exposure, and credited researcher Bob Diachenko. It gave no record count (Confirmed [118]). Comparitech, working with Diachenko, reported nearly 250 million records from 2005 to December 2019 across five Elasticsearch servers, found on 29 December and secured on 30 and 31 December (Reported [119]).

Capital One and the regulator's view of the cloud

On 6 August 2020 the OCC assessed a USD 80 million civil money penalty against Capital One for failing to establish effective risk assessment before migrating significant IT operations to the public cloud and for not correcting the deficiencies in a timely way. The release does not describe the 2019 intrusion (Confirmed [120]).

Cloud tenants after the remote-work shift

CISA's AR21-013A (13 January 2021) described several successful attacks on cloud services in which remote work was a factor: credential-harvesting phishing links, brute force, email forwarding rule abuse and a likely pass-the-cookie MFA bypass. CISA did not tie them to the SolarWinds actor (Confirmed [121]).

Part 6: the government record

Date	Body	Action	Subject	Sources
2019-12-05	US Treasury, DOJ	Sanctions, charges, reward	Evil Corp; Yakubets and Turashev	[51]
2020-01-14	CISA	ED 20-02	January Patch Tuesday	[70]
2020-01-28	Grand jury, N.D. Georgia	Indictment	Four PLA 54th Research Institute members (Equifax)	[13]
2020-07	EU	Sanctions	GRU Unit 74455 over NotPetya (as the UK relays it)	[3]
2020-07-16	CISA	ED 20-03	SIGRed	[72]
2020-08-06	OCC	USD 80 million penalty	Capital One cloud risk management	[120]
2020-08-11	DOJ (FBI poster)	Indictment in public record	APT41 members and Chengdu 404	[18]
2020-09-02	CISA	BOD 20-01	Vulnerability disclosure policies	[77]
2020-09-15	Grand jury, D. New Jersey	Indictment	Heidarian and Farhadi	[24]
2020-09-15 to 2020-09-18	DOJ (FBI summary)	Charges in three cases	Iran-linked defacement, theft and IRGC-linked targeting	[23]
2020-09-17	Treasury OFAC	Designations	APT39, 45 individuals, Rana	[22]
2020-09-18	CISA	ED 20-04	Zerologon	[75]
2020-10-01	Treasury OFAC	Advisory	Sanctions risk of ransom payments	[55]
2020-10-12	E.D. Virginia court, on Microsoft's motion	Court order	Trickbot C2	[48]
2020-10-14	NYDFS	Investigation report	Twitter hack	[63]
2020-10-15	Grand jury, W.D. Pennsylvania	Indictment	Six GRU Unit 74455 officers	[1]
2020-10-19	UK Government	Attribution	GRU against the Olympics and Paralympics	[3]
2020-10-23	Treasury	CAATSA 224 sanctions	TsNIIKhM (Triton)	[10]
2020-12-08	C.D. California	Arrest warrant	RGB officer Jon Chang Hyok	[32]
2020-12-13	CISA	ED 21-01	SolarWinds Orion	[39]
2021-01-05	FBI, CISA, ODNI, NSA	Joint statement	SolarWinds actor likely Russian	[109]
2021-01-27	Europol, Eurojust and eight countries	Takedown	Emotet infrastructure	[67]
2021-04-15	The White House	Attribution and costs	SVR named for SolarWinds	[112]
2021-05-12	The White House	EO 14028	Software supply chain, CSRB, zero trust, EDR, logging	[136]

Date	Body	Action	Subject	Sources
2021-07-21	US Secret Service, Spanish police	Arrest	Joseph O'Connor (Twitter hack)	[64]
2023-03-09	SEC	USD 3 million penalty	Blackbaud disclosures	[57]
2024-04-30	Western Uusimaa District Court (as reported)	Conviction	Vastaamo extortion	[60]
2024-05	FTC	Final order	Blackbaud	[58]
2024-10-09	FTC	Proposed order	Marriott and Starwood	[115]
2024-10-22	SEC	Penalties	Unisys, Avaya, Check Point, Mimecast	[113]

Part 7: the defender view

Edge devices became the perimeter. AA21-209A and the KEV record make the point plainly: the 2020 list leads with VPN, gateway and load-balancer flaws (five of its fourteen CVEs) that were already patched, and four of the most targeted affected remote work, VPN or cloud technology (Confirmed [84][45]). The emergency directives of the year gave federal agencies one to fifteen days to act (Confirmed [70][72][75][39]). Reading them as a new patch-in-days instrument is this study's interpretation, not something the sources state (Inferred [136]).

Credentials outlive the patch. AA20-107A is the year's most practical lesson: patching Pulse Secure closed the flaw but not the access, because stolen Active Directory credentials kept working (Confirmed [89]). D3FEND's Credential Rotation and Domain Account Monitoring countermeasures are the library's pairings for the techniques involved (Part 8).

Identity is the blast radius. AA20-352A told SolarWinds victims that SAML abuse means the whole identity trust store is compromised, that KRBTGT should be reset twice, and that full identity reconstitution should be planned (Confirmed [40]). The library has no D3FEND mapping for SAML token forging (T1606.002), so the countermeasure is the advisory's, not a D3FEND pairing.

Weak authentication ran through the year. Single-factor VPN in the hospital wave, password spraying by Strontium and against healthcare, and Blackbaud's inadequate MFA all turned on authentication (Confirmed [69][6][42][56]); at Twitter, phone pretexting got through two-factor protections, so MFA alone was not enough (Confirmed [62]).

Hospitals and schools got their own playbooks. AA20-302A gave the health sector offline encrypted backups, MFA, RDP closure, paper copies of critical patient information and H-ISAC membership (Confirmed [68]); the CISA and MS-ISAC Ransomware Guide first shipped in September 2020 (Confirmed [135]); AA20-345A quantified the turn toward schools (Confirmed [128]).

What the endpoint saw. Red Canary's 2021 Threat Detection Report, built from its 2020 data, ranks Command and Scripting Interpreter (24 percent of threats) and System Binary Proxy Execution (19 percent) first and second, followed by Create or Modify System Process, Scheduled Task/Job, OS Credential Dumping, Process Injection, Obfuscated Files or Information, Ingress Tool Transfer, System Services and Masquerading. Its top threats were TA551, Cobalt Strike, Qbot, IcedID, Mimikatz, Shlayer, Dridex, Emotet,

TrickBot and Gamarue (Confirmed [134]). This is one vendor's customer base, not the whole year.

The framework changed under the advisories. ATT&CK v7 (8 July 2020) was the first non-beta Enterprise release with sub-techniques, with 156 techniques (down from 266) and 272 sub-techniques; v8 (27 October 2020) retired PRE-ATT&CK into the Reconnaissance and Resource Development tactics and added the Network platform (Confirmed [132][133]). That is why the year's advisories mix sub-technique ids with PRE-ATT&CK ids that no longer exist, and why Part 8 maps several printed ids to their v20.0 successors.

What the year produced in policy. Executive Order 14028, signed 12 May 2021, sets software supply chain security, including SBOMs, in Sec. 4, creates the Cyber Safety Review Board in Sec. 5 with an initial review of the activity behind the December 2020 UCG, and orders zero trust (Sec. 3), EDR (Sec. 7) and logging (Sec. 8) (Confirmed [136]). Reading the rest of the order as a SolarWinds response is Inferred [136].

Part 8: MITRE mappings

Every id below was checked against the library's data files (`data/attack/technique_profiles.jsonl`, `data/attack/ics/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl`, `data/weaknesses/cwe.jsonl`) and the generated pages under `mitre/` on 3 November 2026 [102][122][137], with selected objects opened on attack.mitre.org [46][126][129][130][131]. Names and tactics are those of ATT&CK v20.0. The Basis column says how strong each tie is: **Listed** means the cited source prints the technique id; **Described** means the source describes the behavior and the mapping is this study's; **Reported** means only a press account supports the behavior; **Inferred** marks a mapping no source states.

Left out on purpose: the PRE-ATT&CK ids printed in AA20-258A, which no longer exist in v20.0 [16][133]; T1027.004 and T1036.004 from AA20-259A, whose links in the advisory do not match their titles [25][102]; the deprecated ICS technique T0833 from AA20-205A [125][102]. Printed ids that ATT&CK later revoked are shown under their successors from `data/attack/superseded_by.jsonl`: T1562.001 as T1685, T1562.004 as T1686 and T1656 as T1684.001. AA20-352A prints T1101.001 and T1101.003 where its links resolve to Password Guessing and Password Spraying; T1101 itself is the revoked Security Support Provider technique (successor T1547.005), so the table uses T1110.001 and T1110.003 (correction Inferred [40][102]).

ATT&CK Enterprise techniques

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1595.002	Vulnerability Scanning	reconnaissance	Described	Acunetix scans of state election websites, 20 to 28 Sep 2020; APT29 vulnerability scanning before exploitation in 2020	[26][5]
T1598	Phishing for Information	reconnaissance	Described	Phosphorus spoofed conference invitations (28 Oct 2020); Zinc fake-recruiter credential theft (13 Nov 2020)	[27][7]
T1598.003	Spearphishing Link	reconnaissance	Listed	AR21-013A credential-harvesting links against cloud tenants (13 Jan 2021)	[121]
T1583.001	Domains	resource-development	Described	Coronavirus-themed domains registered for phishing (AA20-099A, 8 Apr 2020)	[41]
T1584	Compromise Infrastructure	resource-development	Listed	AA20-352A lists it for the SolarWinds actor (17 Dec 2020); BLINDINGCAN C2 on compromised infrastructure (19 Aug 2020); SocGholish served from compromised sites (Jun 2020)	[40][30][53]
T1585.001	Social Media Accounts	resource-development	Described	Fake LinkedIn HR profiles in Operation In(ter)ception (17 Jun 2020)	[33]
T1588.003	Code Signing Certificates	resource-development	Described	Code-signing certificates stolen from two companies for the WIZVERA VeraPort attack (16 Nov 2020)	[34]
T1078	Valid Accounts	stealth, persistence, privilege-escalation, initial-access	Listed	AA20-107A, AA20-283A and AA20-352A; Twitter employee credentials (15 Jul 2020); Marriott franchise employee logins (disclosed 31 Mar 2020)	[89][9][40][63][114]
T1133	External Remote Services	persistence, initial-access	Listed	AA20-107A, AA20-283A and AA20-352A; Maze access through Citrix and RDP support accounts; single-factor VPN in the October hospital wave	[89][9][40][49][69]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1189	Drive-by Compromise	initial-access	Listed	AA20-296A (22 Oct 2020); Kimsuky watering holes (AA20-301A); SocGholish fake updates on compromised news sites (Jun 2020)	[8][31][52][53]
T1190	Exploit Public-Facing Application	initial-access	Listed	AA20-258A, AA20-259A, AA20-283A and AA20-296A; APT29 vaccine targeting (16 Jul 2020); Iranian election-site SQL injection and traversal (Sep to Oct 2020); APT41 global campaign (Jan to Mar 2020); Equifax entry (Reported)	[16][25][9][8][5][26][87][14]
T1195.001	Compromise Software Dependencies and Development Tools	initial-access	Listed	AA20-352A (17 Dec 2020)	[40]
T1195.002	Compromise Software Supply Chain	initial-access	Listed	AA20-352A; tainted Orion updates released Mar to Jun 2020; SignSight trojanized VGCA installers (17 Dec 2020); WIZVERA VeraPort (16 Nov 2020)	[40][104][20][34]
T1199	Trusted Relationship	initial-access	Listed	FASTCash 2.0 (AA20-239A, 26 Aug 2020); reseller Azure account abuse reported to CrowdStrike (15 Dec 2020); listed on C0024	[29][107][129]
T1566.001	Spearphishing Attachment	initial-access	Listed	Kimsuky's most observed access (AA20-301A); FASTCash 2.0 (AA20-239A); Maze macro phishing; APT32 COVID-themed attachments (likely); Emotet thread hijacking with password-protected archives (AA20-280A)	[31][29][49][21][65]
T1566.002	Spearphishing Link	initial-access	Listed	AA20-258A; AA20-301A; BazarLoader Google Docs link lures (AA20-302A, 28 Oct 2020)	[16][31][68]
T1566.003	Spearphishing via Service	initial-access	Described	LinkedIn job offers in Operation In(ter)ception (Sep to Dec 2019, published 17 Jun 2020)	[33]
T1566.004	Spearphishing Voice	initial-access	Inferred	Phone spear phishing of Twitter employees (15 Jul 2020); the technique label is ours	[62][63]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1047	Windows Management Instrumentation	execution	Described	Maze (WMIC); WastedLocker intrusions; the October hospital wave	[49][53][68]
T1059	Command and Scripting Interpreter	execution	Listed	Red Canary's most prevalent technique of 2020 (24 percent of threats)	[134]
T1059.001	PowerShell	execution	Listed	AA20-259A; AA20-301A; WastedLocker intrusions (Jun 2020); lateral movement in the October hospital wave	[25][31][53][68]
T1059.003	Windows Command Shell	execution	Listed	Ryuk technique table in AA20-302A (28 Oct 2020)	[68]
T1072	Software Deployment Tools	execution, lateral-movement	Listed	AA20-258A (14 Sep 2020)	[16]
T1106	Native API	execution	Listed	Ryuk technique table in AA20-302A	[68]
T1204.001	Malicious Link	execution	Listed	AA20-258A; BazarLoader link lures in AA20-302A	[16][68]
T1204.002	Malicious File	execution	Described	SocGholish fake browser updates in WastedLocker intrusions (Jun 2020)	[52]
T1569	System Services	execution	Listed	Red Canary's ninth most prevalent technique of 2020	[134]
T1569.002	Service Execution	execution	Listed	AA20-352A; Pay2Key spread by psexec within an hour (6 Nov 2020); PsExec in Maze and WastedLocker intrusions	[40][28][49][53]
T1053	Scheduled Task/Job	execution, persistence, privilege-escalation	Listed	Red Canary's fourth most prevalent technique of 2020	[134]
T1053.005	Scheduled Task	execution, persistence, privilege-escalation	Listed	AA20-259A; scheduled tasks for KEGTAP, SINGLEMALT and WINEKEY loaders (28 Oct 2020)	[25][69]
T1078.003	Local Accounts	stealth, persistence, privilege-escalation, initial-access	Described	Blackbaud intruder used existing local administrator accounts (FTC, 2024, on the 2020 intrusion)	[56]
T1136	Create Account	persistence	Described	Blackbaud intruder created new administrator accounts (FTC, 2024)	[56]
T1197	BITS Jobs	stealth, persistence, execution	Described	BITS persistence for the Bazar loaders; APT41 BITSAdmin downloads (Mar 2020)	[69][87]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1505.003	Web Shell	persistence	Listed	AA20-259A web shells (ChunkyTuna, Tiny, China Chopper); Iranian web shell uploads to election sites; AA20-301A	[25][26][31]
T1542.001	System Firmware	stealth, persistence	Described	MosaicRegressor dropped by rogue UEFI firmware (5 Oct 2020)	[19]
T1543	Create or Modify System Process	persistence, privilege-escalation	Listed	Red Canary's third most prevalent technique of 2020	[134]
T1543.003	Windows Service	persistence, privilege-escalation	Listed	AA20-352A; APT41 service installation in the 2020 global campaign	[40][87]
T1547.001	Registry Run Keys / Startup Folder	persistence, privilege-escalation	Listed	Ryuk table in AA20-302A (label misprinted T1047.001); KEGTAP Startup folder LNK	[68][69]
T1547.004	Winlogon Helper DLL	persistence, privilege-escalation	Described	Winlogon Userinit persistence for the Bazar loaders (28 Oct 2020)	[69]
T1055	Process Injection	stealth, privilege-escalation	Listed	Ryuk table in AA20-302A; Red Canary's sixth most prevalent technique of 2020	[68][134]
T1068	Exploitation for Privilege Escalation	privilege-escalation	Inferred	Netlogon CVE-2020-1472 used to escalate in AA20-283A; CISA did not list the id	[9][79]
T1078.002	Domain Accounts	stealth, persistence, privilege-escalation, initial-access	Listed	AA20-283A: domain access after Netlogon CVE-2020-1472 (9 Oct 2020)	[9]
T1134	Access Token Manipulation	stealth, privilege-escalation	Listed	Ryuk table in AA20-302A	[68]
T1548.002	Bypass User Account Control	privilege-escalation	Described	WastedLocker UAC bypass through a winmm.dll hijack (23 Jun 2020)	[52]
T1014	Rootkit	stealth	Described	Drovorub kernel-module rootkit (13 Aug 2020)	[4][46]
T1027	Obfuscated Files or Information	stealth	Listed	AA20-352A; Red Canary's seventh most prevalent technique of 2020	[40][134]
T1027.003	Steganography	stealth	Listed	AA20-352A	[40]
T1036	Masquerading	stealth	Listed	Red Canary's tenth most prevalent technique of 2020	[134]
T1036.005	Match Legitimate Resource Name or Location	stealth	Listed	Ryuk table in AA20-302A	[68]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1070.004	File Deletion	stealth	Listed	AA20-352A; AA20-239A	[40][29]
T1218	System Binary Proxy Execution	stealth	Listed	Red Canary's second most prevalent technique of 2020 (19 percent)	[134]
T1218.005	Mshta	stealth	Listed	AA20-301A (Kimsuky)	[31]
T1564.004	NTFS File Attributes	stealth	Described	WastedLocker payload kept in an NTFS alternate data stream	[52]
T1684.001	Impersonation	stealth	Described	Callers posed as Twitter IT staff (NYDFS, 14 Oct 2020); T1656 Impersonation was revoked in v20.0 with successor T1684.001	[63][102]
T1553.002	Code Signing	defense-impairment	Listed	AA20-352A (Orion DLL signed with the SolarWinds certificate); WIZVERA stolen certificates; In(ter)ception signed malware	[40][34][33]
T1685	Disable or Modify Tools	defense-impairment	Listed	AA20-302A lists T1562.001, revoked in v20.0 with successor T1685; WastedLocker disabled Microsoft Defender	[68][102][52]
T1686	Disable or Modify System Firewall	defense-impairment	Listed	AA20-301A lists T1562.004, revoked in v20.0 with successor T1686	[31][102]
T1003	OS Credential Dumping	credential-access	Listed	AA20-107A; AA20-301A; Red Canary's fifth most prevalent technique of 2020	[89][31][134]
T1003.001	LSASS Memory	credential-access	Listed	AA20-258A; AA20-259A; Mimikatz and ProcDump in Maze, WastedLocker and the October hospital wave	[16][25][49][53][68]
T1003.003	NTDS	credential-access	Described	ntds.dit export in the Bazar-to-Ryuk intrusions (28 Oct 2020)	[69]
T1056.001	Keylogging	collection, credential-access	Listed	AA20-301A (Kimsuky)	[31]
T1110	Brute Force	credential-access	Listed	AA20-296A; AR21-013A; Strontium brute force against campaigns (10 Sep 2020) and vaccine makers (13 Nov 2020)	[8][121][6][7]
T1110.001	Password Guessing	credential-access	Listed	AA20-352A, printed there as T1101.001; the correction is Inferred	[40][102]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1110.003	Password Spraying	credential-access	Listed	AA20-352A (printed as T1101.003); Strontium password spray; AA20-126A spraying against healthcare (5 May 2020)	[40][6][7][42]
T1110.004	Credential Stuffing	credential-access	Listed	AA20-258A	[16]
T1558.003	Kerberoasting	credential-access	Described	Kerberoasting in the Bazar-to-Ryuk intrusions (28 Oct 2020)	[69]
T1606.002	SAML Tokens	credential-access	Described	Forged SAML tokens after on-premises compromise (13 and 17 Dec 2020); listed on C0024	[105][40][129]
T1012	Query Registry	discovery	Listed	AA20-352A	[40]
T1016	System Network Configuration Discovery	discovery	Listed	Ryuk table in AA20-302A	[68]
T1046	Network Service Discovery	discovery	Listed	AA20-258A	[16]
T1057	Process Discovery	discovery	Listed	AA20-352A; Ryuk table in AA20-302A	[40][68]
T1083	File and Directory Discovery	discovery	Listed	AA20-352A; Ryuk table in AA20-302A	[40][68]
T1482	Domain Trust Discovery	discovery	Inferred	AdFind and BloodHound named in Maze intrusions; the mapping is ours	[49]
T1518	Software Discovery	discovery	Listed	AA20-352A	[40]
T1518.001	Security Software Discovery	discovery	Listed	AA20-352A	[40]
T1021	Remote Services	lateral-movement	Listed	AA20-107A	[89]
T1021.001	Remote Desktop Protocol	lateral-movement	Listed	AA20-239A; Pay2Key access presumed over RDP; Maze; the October hospital wave	[29][28][49][68]
T1021.006	Windows Remote Management	lateral-movement	Described	WinRM lateral movement in AA20-302A	[68]
T1550.004	Web Session Cookie	lateral-movement	Listed	AR21-013A likely pass-the-cookie MFA bypass; listed on C0024	[121][129]
T1563.002	RDP Hijacking	lateral-movement	Described	Maze use of tscon	[49]
T1114	Email Collection	collection	Listed	AA20-258A (Exchange CVE-2020-0688 used to collect email)	[16]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1114.003	Email Forwarding Rule	collection	Listed	AR21-013A; AA20-301A	[121][31]
T1560	Archive Collected Data	collection	Reported	Equifax data archived and split before exfiltration (press account of the indictment)	[14]
T1560.001	Archive via Utility	collection	Listed	AA20-259A (7-Zip); Maze (7-Zip)	[25][49]
T1071.001	Web Protocols	command-and-control	Listed	AA20-352A	[40]
T1071.004	DNS	command-and-control	Listed	AA20-352A; SUNBURST DNS C2 via avsvmcloud[.]com subdomains; Anchor_DNS tunnelling (AA20-302A)	[40][37][68]
T1090	Proxy	command-and-control	Listed	AA20-107A	[89]
T1090.002	External Proxy	command-and-control	Listed	AA20-258A	[16]
T1090.003	Multi-hop Proxy	command-and-control	Listed	AA20-258A; Strontium through Tor and more than 1,000 rotating IPs; Equifax traffic through about 34 servers (Reported)	[16][6][14]
T1105	Ingress Tool Transfer	command-and-control	Listed	AA20-352A; AA20-259A; Red Canary's eighth most prevalent technique of 2020	[40][25][134]
T1132.001	Standard Encoding	command-and-control	Listed	AA20-352A	[40]
T1219	Remote Access Tools	command-and-control	Listed	AA20-301A	[31]
T1568.002	Domain Generation Algorithms	command-and-control	Listed	AA20-352A	[40]
T1572	Protocol Tunneling	command-and-control	Listed	AA20-259A (FRP, Chisel, ngrok); Maze (ngrok)	[25][49]
T1573.002	Asymmetric Cryptography	command-and-control	Listed	AA20-258A	[16]
T1030	Data Transfer Size Limits	exfiltration	Reported	Equifax archives split into 600 MB segments (press account)	[14]
T1567.002	Exfiltration to Cloud Storage	exfiltration	Described	Turla Crutch exfiltration to Dropbox (2 Dec 2020)	[11]
T1485	Data Destruction	impact	Listed	AA20-239A (FASTCash 2.0)	[29]
T1486	Data Encrypted for Impact	impact	Listed	Ryuk table in AA20-302A; AA20-107A; Garmin systems encrypted 23 Jul 2020; Maze; WastedLocker; Pay2Key	[68][89][54][49][52][28]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1489	Service Stop	impact	Listed	Ryuk table in AA20-302A	[68]
T1490	Inhibit System Recovery	impact	Listed	Ryuk table and vssadmin shadow-copy deletion in AA20-302A; WastedLocker shadow-copy deletion	[68][52]
T1561.002	Disk Structure Wipe	impact	Listed	AA20-239A (FASTCash 2.0)	[29]
T1565.002	Transmitted Data Manipulation	impact	Listed	AA20-239A fraudulent transfers and ATM cash-outs	[29]
T1657	Financial Theft	impact	Described	Twitter bitcoin scam (over USD 118,000); Blackbaud paid 24 Bitcoin; Vastaamo patient extortion (Reported)	[63][56][59][60]

ATT&CK for ICS techniques

AA20-205A (23 July 2020, NSA and CISA) described the operational technology pattern of the year: spear phishing into IT followed by a pivot to OT, commodity ransomware reaching IT and OT, internet-accessible PLCs and modified control logic, and mapped it to ATT&CK for ICS (Confirmed [125]). The library has no generated ICS technique pages, so these ids link to attack.mitre.org; each was checked in `data/attack/ics/technique_profiles.jsonl` [102].

Id	Name (ATT&CK for ICS v20.0)	Tactic	What AA20-205A describes	Source
T0883	Internet Accessible Device	initial-access	Internet-accessible PLCs and OT devices	[125]
T0885	Commonly Used Port	command-and-control	Commonly used ports for OT traffic	[125]
T0869	Standard Application Layer Protocol	command-and-control	Standard application-layer protocols	[125]
T0843	Program Download	lateral-movement	Program download to controllers	[125]
T0836	Modify Parameter	impair-process-control	Modified parameters	[125]
T0826	Loss of Availability	impact	Loss of availability	[125]
T0829	Loss of View	impact	Loss of view	[125]
T0828	Loss of Productivity and Revenue	impact	Loss of productivity and revenue (commodity ransomware on IT and OT)	[125]
T0831	Manipulation of Control	impact	Manipulation of control	[125]

The Triton tools behind the October 2020 TsNIIKhM sanctions [10] are the ICS software object S1009 Triton in the library's ICS data, which has no generated page [102]. The live Ryuk page also lists the ICS technique T0828 (Confirmed [131]).

ATT&CK groups, software and campaigns

Groups (every page exists under `/mitre/groups/`; Microsoft's actor names are mapped only where the library's alias list carries them [102]):

Id	Group (library name)	The 2020 tie	Sources
G0034	Sandworm Team	Exim exploitation; the October 2020 indictment of Unit 74455; Olympic Destroyer attribution	[124][1][3][126]
G0007	APT28 (library aliases include STRONTIUM)	Drovorub; Strontium's election and vaccine-maker campaigns	[4][46][6][7]
G0016	APT29 (aliases include UNC2452, NOBELIUM)	Vaccine research targeting with WellMess and WellMail; SolarWinds	[5][37][40][112]
G0035	Dragonfly (aliases include Berserk Bear, Energetic Bear)	AA20-296A	[8]
G0010	Turla	Crutch	[11]
G0096	APT41	2020 indictment and global campaign; home study APT41: the public record	[18][87]
G0128	ZIRCONIUM (alias APT31)	Election-season targeting	[6]
G0050	APT32	COVID-19 espionage against Chinese government targets	[21]
G0087	APT39	OFAC designation with Rana	[22]
G0117	Fox Kitten (aliases include Pioneer Kitten, UNC757)	AA20-259A	[25]
G0059	Magic Hound (aliases include Phosphorus, Charming Kitten)	Campaign-account attacks; conference lures	[6][27]
G0032	Lazarus Group (aliases include ZINC)	WIZVERA VeraPort; MATA; Zinc's fake-recruiter lures; FASTCash overlap	[34][35][7][29]
G0082	APT38 (alias BeagleBoyz)	FASTCash 2.0; the Jon Chang Hyok warrant	[29][32]
G0094	Kimsuky	AA20-301A	[31]
G0102	Wizard Spider (aliases include UNC1878, FIN12)	TrickBot, Bazar and Ryuk against hospitals	[68][69]
G0119	Indrik Spider (alias Evil Corp)	Sanctions; WastedLocker	[51][52]
G0037	FIN6	Linked to one Maze affiliate group	[49]
G0127	TA551	Red Canary's top threat of 2020	[134]

Not mapped, because the library data has no matching group object or alias: the PLA 54th Research Institute (Equifax), XDSpy, Microsoft's Cerium, the Twitter attackers, and the unnamed actors behind Garmin, UHS, Blackbaud and Vastaamo [102].

Software (every page exists under `/mitre/software/`):

Id	Software	The 2020 tie	Sources
S0365	Olympic Destroyer	October 2020 attribution and indictment	[3][1]
S0368	NotPetya	October 2020 indictment; EU sanctions	[1][2][3]
S0089, S0604, S0606, S1010	BlackEnergy, Industroyer, Bad Rabbit, VPNFilter	Tied to Unit 74455 by the UK	[3]
S0502	Drovorub	NSA and FBI, 13 Aug 2020	[4][46]
S0514, S0515	WellMess, WellMail	APT29 vaccine targeting	[5][130]
S0538	Crutch	Turla	[11]
S0011	Taidoor	AR20-216A	[17]
S0520	BLINDINGCAN	AR20-232A	[30]
S0376, S0593	HOPLIGHT, ECCENTRICBANDWAGON	FASTCash 2.0	[29]
S0556	Pay2Key	Check Point, Nov 2020	[28]
S0559, S0560, S0562, S0565	SUNBURST, TEARDROP, SUNSPOT, Raindrop	C0024	[37][129]
S0588, S0597, S0589	GoldMax, GoldFinder, Sibot	C0024	[129]
S0154	Cobalt Strike	APT41, AA20-258A, Maze, WastedLocker, the hospital wave, C0024; Red Canary's second threat	[87][16][49][52][68][129][134]
S0002	Mimikatz	AA20-258A, AA20-283A, Maze, the hospital wave, C0024	[16][9][49][68][129]
S0446	Ryuk	The hospital wave; K-12	[68][69][128][131]
S0266	TrickBot	COVID lures; Microsoft's court order; the hospital wave	[41][48][68]
S0534, S0504, S0575	Bazar, Anchor, Conti	AA20-302A	[68][69]
S0367, S0650	Emotet, QakBot	AA20-280A; the 2021 takedown	[65][67]
S0449, S0554	Maze, Egregor	Double extortion; Maze shutdown	[49][50]

Id	Software	The 2020 tie	Sources
S0612, S1124, S0570, S0384	WastedLocker, SocGholish, BitPaymer, Dridex	Evil Corp	[51][52][53]
S0496	REvil	Pulse Secure delivery (media, as CISA relays it); K-12	[88][128]
S0331	Agent Tesla	COVID-19 lures	[41]
S0521, S0552, S0029, S0363	BloodHound, AdFind, PsExec, Empire	Ransomware intrusion tooling	[49][53][68]
S0190	BITSAdmin	APT41 global campaign	[87]
S0483	IcedID	Red Canary's fourth threat	[134]

Not linked, because the library software data has no object by that name: MATA, MosaicRegressor, METALJACK, ELECTRICFISH, CROWDEDFLOUNDER, VIVACIOUSGIFT, COPPERHEDGE, NOTROBIN and CovidLock [102].

Campaigns (pages exist under `/mitre/campaigns/`):

Id	Campaign	Window in library data	The 2020 tie	Sources
C0024	SolarWinds Compromise (APT29)	2019-08 to 2021-01	Orion supply chain; home study SolarWinds and SUNBURST	[129][40][102]
C0022	Operation Dream Job (Lazarus)	2019-09 to 2020-08	Operation In(ter)ception	[33][102]
C0005	Operation Spalax	2019-11 to 2021-01	Colombian targets in 2020	[44][102]

No ATT&CK campaign object covers 2020 edge-device mass exploitation, the 2020 ransomware events, or Sandworm's 2019 to 2020 activity [102][126].

CWE and CAPEC

The CWE ids are those NVD lists for each CVE, except CVE-2020-0796, whose CWE-119 is taken from KEV (Confirmed [45][80][95][96][100]). The CAPEC column lists the attack patterns the library's `data/weaknesses/cwe.jsonl` relates to that CWE, linked where a generated page exists; picking the closest pattern is this study's reading (Inferred [102]).

CWE	Weakness	CVEs from the 2020 record	CAPEC the library relates
CWE-22	Path traversal	CVE-2019-19781, CVE-2019-11510, CVE-2018-13379, CVE-2020-5902	CAPEC-126 Path Traversal (the library also relates CAPEC-64, 76, 78 and 79)

CWE	Weakness	CVEs from the 2020 record	CAPEC the library relates
CWE-78	OS command injection	CVE-2019-11539, CVE-2019-10149	CAPEC-88 OS Command Injection
CWE-611	XML external entity reference	CVE-2019-9670	CAPEC-221
CWE-347	Improper verification of cryptographic signature	CVE-2020-2021	CAPEC-463, CAPEC-475
CWE-306	Missing authentication for critical function	CVE-2020-6287	CAPEC-36 (the library also relates CAPEC-12, 62, 166 and 216)
CWE-295	Improper certificate validation	CVE-2020-0601	CAPEC-459, CAPEC-475
CWE-119	Memory buffer bounds	CVE-2020-0796	CAPEC-100 Overflow Buffers
CWE-287, CWE-706, CWE-20	Improper authentication; incorrectly resolved name or reference; improper input validation	CVE-2020-0688, CVE-2020-15505, CVE-2020-1350	broad classes; no single pattern chosen
CWE-755	Improper handling of exceptional conditions	CVE-2017-5638 (Equifax link Inferred)	none in library data
NVD-CWE-noinfo	none	CVE-2020-1472	none

ATT&CK itself relates CAPEC entries to several techniques in the Enterprise table, among them CAPEC-565 for Password Spraying and CAPEC-650 for Web Shell, as the library's technique profiles record them [102]. SUNBURST has no CVE: it was inserted code from a build-system compromise (Confirmed [104]).

D3FEND countermeasures

Pairings come from `data/attack/technique_to_d3fend.jsonl`; every page exists under `/mitre/d3fend/` [102]. Only pairings the record gives a reason to apply are listed.

Technique from the record	D3FEND countermeasures the library maps	Why it applies in 2020
T1190 Exploit Public-Facing Application	Inbound Traffic Filtering, Network Traffic Signature Analysis, Process Segment Execution Prevention	Edge-device exploitation all year; CISA's block-SMB-at-the-edge advice [93][84]
T1195.002 Compromise Software Supply Chain	Software Inventory, Software Update, Asset Vulnerability Enumeration, Restore Software	Finding and removing affected Orion versions under ED 21-01 [39]
T1110.003 Password Spraying	Multi-factor Authentication, Credential Rotation, Connection Attempt Analysis, Decoy User Credential	Strontium; AA20-126A healthcare spraying [6][42]
T1078.002 Domain Accounts	Domain Account Monitoring, Account Locking, Access Modeling, User Account Permissions	Zerologon chains; Pulse credentials reused after patching [9][89]
T1003.003 NTDS	Credential Rotation, Credential Hardening, Multi-factor Authentication	ntds.dit export before Ryuk [69]

Technique from the record	D3FEND countermeasures the library maps	Why it applies in 2020
T1003.001 LSASS Memory	Process Spawn Analysis, Process Lineage Analysis, Hardware-based Process Isolation	Mimikatz and ProcDump in nearly every intrusion set [16][49][68]
T1558.003 Kerberoasting	RPC Traffic Analysis	Bazar-to-Ryuk intrusions [69]
T1071.004 DNS	DNS Traffic Analysis, DNS Denylisting, Outbound Traffic Filtering	SUNBURST and Anchor_DNS C2 [37][68]
T1566.001, T1566.002 Spearphishing	Email Filtering, Email Removal, Content Quarantine	COVID-19 lures, Emotet, Kimsuky, Bazar [41][65][31][68]
T1505.003 Web Shell	File Integrity Monitoring, Process Spawn Analysis	Pioneer Kitten and Iranian election-site web shells [25][26]
T1021.001 Remote Desktop Protocol	Remote Terminal Session Detection, Session Termination	Maze, Pay2Key, the hospital wave [49][28][68]
T1486 Data Encrypted for Impact	Restore File, File Integrity Monitoring, Decoy File, Local File Permissions	Every ransomware event of the year; AA20-302A backup advice [68]
T1490 Inhibit System Recovery	Restore Configuration, Configuration Inventory, Software Update	Shadow-copy deletion by Ryuk and WastedLocker [68][52]
T1542.001 System Firmware	System Firmware Verification, Firmware Verification	MosaicRegressor [19]

The library data has no D3FEND mapping for T1606.002 SAML Tokens, T1553.002 Code Signing, T1110 Brute Force, T1566.004 Spearphishing Voice or T1568.002 Domain Generation Algorithms; none is invented here [102].

Navigator layers

The study's techniques are saved as two ATT&CK Navigator layers pinned to ATT&CK v20: the Enterprise layer navigator/library-layers/chronicle-2020.json and the ICS layer navigator/case-studies/chronicle-2020-ics.json, both listed on the Navigator layers page. The Enterprise layer scores each technique by its Basis: 100 where the source prints the id, 75 where the source describes the behavior, 50 where only a press account supports it, and 40 for an Inferred mapping. Every entry's comment names the source numbers in the Sources table below.

Cross-cutting themes

The perimeter moved to the VPN, and everyone found it. Russian (APT29, Berserk Bear), Chinese (MSS-affiliated actors, APT41) and Iranian (Pioneer Kitten) state actors and ransomware crews all used the same short list of gateway flaws within months of one another (Confirmed [5][8][16][87][25][89]). The shared list is the year's most useful fact for a defender: one patch queue served against every actor.

Credentials were the real prize. The Pulse Secure reuse, Strontium's spraying, Twitter's phone pretexting, Blackbaud's admin accounts, Marriott's franchise logins and the SAML forgery at the end of the year all show attackers turning access into identity (Confirmed [89][6][63][56][114][105]).

Health care was a target twice over. Espionage services wanted vaccine research (Confirmed [5][7][15][42]); criminal crews wanted hospitals' money and disrupted care (Confirmed [61][68][69]).

Trust relationships were the supply chain. A build server (SolarWinds), a government certification authority's download page (SignSight), a mandatory security plug-in (WIZVERA VeraPort), a cloud reseller's account and a vendor's certificate (Mimecast) all carried intrusions into customers who had done nothing wrong (Confirmed [104][20][34][107][110]).

Disclosure became a liability in its own right. The SEC penalized Blackbaud for what it told investors, not for being breached, and four years after SolarWinds penalized four companies over how they described it (Confirmed [57][113]). NYDFS used the Twitter case to argue for regulating the largest platforms (Confirmed [63]).

Governments shifted from warning to naming. The year carried a dense run of indictments, sanctions, emergency directives and a private-sector court order (Part 6). Whether that deterred anyone is not something the sources measure.

What is overstated and what is understated

This section is the study's reading of the record (Inferred).

- **Overstated: zero-days.** The year's mass exploitation ran on patched bugs, most disclosed in the prior two years [84], and the FireEye tools stolen in December held no zero-days [36].
- **Overstated: election vote tampering.** The record shows targeting of campaigns and election websites, voter registration data taken in at least one state, and intimidation emails [6][26]; CISA found no evidence that election data integrity was compromised [9].
- **Understated: what happens after the patch.** Stolen credentials and web shells survived patching (Pulse Secure, Pioneer Kitten) [89][25].
- **Understated: the people behind the data.** Vastaamo's attacker extorted patients individually, which a breach count does not capture (Reported [59][60]).
- **Understated: the identity provider.** The SolarWinds advisory's most demanding instruction was rebuilding identity, not removing a DLL [40].

Discrepancies in the record

- **18,000 or 16,000.** SolarWinds (December 2020) and the UCG (January 2021) used about 18,000 affected customers; the White House (April 2021) said more than 16,000 systems worldwide [104][109][112]. Both are given with their sources.
- **C0024's size.** The live C0024 page lists 96 technique entries while the library's `campaigns.jsonl` records 71; the difference is unresolved, so this study prints no C0024 technique count [129][102].
- **Misprinted ids in advisories.** AA20-352A prints T1101.001 and T1101.003 for password guessing and spraying; AA20-302A labels T1547.001 as T1047.001 and lists T1562.001, which ATT&CK v20.0 revoked [40][68][102].
- **CWE by source.** KEV records CWE-330 for Zerologon and CWE-20 for Struts CVE-2017-5638 where NVD gives NVD-CWE-noinfo and CWE-755; the CWE table follows NVD [45][80].

- **Marriott's dates.** The FTC puts the 2020 breach from September 2018 to February 2020; the mid-January 2020 start commonly attributed to Marriott's own release was not checked because the release did not open [115].
- **Microsoft's record count.** Microsoft gave no count; the nearly 250 million figure is the researcher's publisher's (Reported [118][119]).
- **SignSight's window.** ESET found the trojanized installers in early December 2020 but believed they were no longer served by the end of August 2020 [20].
- **The library's own SolarWinds entry.** NOTABLE_INCIDENTS.md lists the NSA among confirmed SolarWinds victims, which no source opened for this study supports; the library also has no entries for Marriott 2020, easyJet, Twitter, Blackbaud, the Capital One OCC penalty, the Microsoft support database or Mimecast [123].
- **Equifax method.** The intrusion details come from press coverage of the indictment; the DOJ release did not open, and the Struts CVE link is Inferred [14].

Sources

All sources were opened on 3 November 2026. Grade is the source's evidence grade as used in this study.

#	Source	URL	Opened	Grade
1	FBI, wanted poster: Yuriy Sergeyevich Andrienko and five other GRU Unit 74455 officers (indictment of 15 Oct 2020)	https://www.fbi.gov/wanted/cyber/yuriy-sergeyevich-andrienko	2026-11-03	Confirmed
2	FBI, Deputy Director David Bowdich's remarks announcing the indictment of six Russian intelligence officers, 19 Oct 2020	https://www.fbi.gov/news/press-releases/fbi-deputy-director-david-bowdichs-remarks-at-press-conference-announcing-cyber-related-indictment-of-six-russian-intelligence-officers	2026-11-03	Confirmed
3	UK Government, UK exposes series of Russian cyber attacks against Olympic and Paralympic Games, 19 Oct 2020	https://www.gov.uk/government/news/uk-exposes-series-of-russian-cyber-attacks-against-olympic-and-paralympic-games	2026-11-03	Confirmed
4	FBI, NSA and FBI expose previously undisclosed Russian malware Drovorub, 13 Aug 2020	https://www.fbi.gov/news/press-releases/nsa-and-fbi-expose-russian-previously-undisclosed-malware-drovorub-in-cybersecurity-advisory	2026-11-03	Confirmed
5	UK NCSC, Advisory: APT29 targets COVID-19 vaccine development, 16 Jul 2020	https://www.ncsc.gov.uk/news/advisory-apt29-targets-covid-19-vaccine-development	2026-11-03	Confirmed
6	Microsoft On the Issues, New cyberattacks targeting U.S. elections, 10 Sep 2020	https://blogs.microsoft.com/on-the-issues/2020/09/10/cyberattacks-us-elections-trump-biden/	2026-11-03	Confirmed
7	Microsoft On the Issues, Cyberattacks targeting health care must stop, 13 Nov 2020	https://blogs.microsoft.com/on-the-issues/2020/11/13/health-care-cyberattacks-covid-19-paris-peace-forum/	2026-11-03	Confirmed
8	CISA and FBI, AA20-296A, Russian state-sponsored APT actor compromises U.S. government targets, 22 Oct 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-296a	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
9	CISA and FBI, AA20-283A, APT actors chaining vulnerabilities against SLTT, critical infrastructure and elections organizations, 9 Oct 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-283a	2026-11-03	Confirmed
10	US Treasury, sm1162, sanctions on the Russian research institute connected to Triton, 23 Oct 2020	https://home.treasury.gov/news/press-releases/sm1162	2026-11-03	Confirmed
11	ESET WeLiveSecurity, Turla Crutch: keeping the back door open, 2 Dec 2020	https://www.welivesecurity.com/2020/12/02/turla-crutch-keeping-back-door-open/	2026-11-03	Confirmed
12	ESET WeLiveSecurity, XDSpy: stealing government secrets since 2011, 2 Oct 2020	https://www.welivesecurity.com/2020/10/02/xdspy-stealing-government-secrets-since-2011/	2026-11-03	Confirmed
13	FBI, wanted poster: Chinese PLA members, 54th Research Institute (Equifax indictment)	https://www.fbi.gov/wanted/cyber/chinese-pla-members-54th-research-institute	2026-11-03	Confirmed
14	BleepingComputer, US charges Chinese military hackers for Equifax breach, 10 Feb 2020	https://www.bleepingcomputer.com/news/security/us-charges-chinese-military-hackers-for-equifax-breach/	2026-11-03	Reported
15	CISA, FBI and CISA warn against Chinese targeting of COVID-19 research organizations, 13 May 2020	https://www.cisa.gov/news-events/news/fbi-and-cisa-warn-against-chinese-targeting-covid-19-research-organizations	2026-11-03	Confirmed
16	CISA, AA20-258A, Chinese Ministry of State Security-affiliated cyber threat actor activity, 14 Sep 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-258a	2026-11-03	Confirmed
17	CISA, FBI and DoD, AR20-216A, malware analysis of the TAIDOOR RAT, 3 Aug 2020	https://www.cisa.gov/news-events/analysis-reports/ar20-216a	2026-11-03	Confirmed
18	FBI, wanted poster: APT 41 Group	https://www.fbi.gov/wanted/cyber/apt-41-group	2026-11-03	Confirmed
19	Kaspersky Securelist, MosaicRegressor: lurking in the shadows of UEFI, 5 Oct 2020	https://securelist.com/mosaicregressor/98849/	2026-11-03	Confirmed
20	ESET WeLiveSecurity, Operation SignSight: supply-chain attack against a certification authority in Southeast Asia, 17 Dec 2020	https://www.welivesecurity.com/2020/12/17/operation-signsight-supply-chain-attack-southeast-asia/	2026-11-03	Confirmed
21	Mandiant (Google Cloud), APT32 targeting Chinese government in COVID-19 related espionage, 22 Apr 2020	https://cloud.google.com/blog/topics/threat-intelligence/apt32-targeting-chinese-government-in-covid-19-related-espionage	2026-11-03	Confirmed
22	US Treasury, sm1127, sanctions on cyber actors backed by Iranian intelligence (APT39, Rana), 17 Sep 2020	https://home.treasury.gov/news/press-releases/sm1127	2026-11-03	Confirmed
23	FBI, Iran at center of cyber crime charges in three cases, 18 Sep 2020	https://www.fbi.gov/news/stories/iran-at-center-of-cyber-crime-charges-in-three-cases-091820	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
24	FBI, wanted poster: Hooman Heidarian	https://www.fbi.gov/wanted/cyber/hooman-heidarian	2026-11-03	Confirmed
25	CISA and FBI, AA20-259A, Iran-based threat actor exploits VPN vulnerabilities, 15 Sep 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-259a	2026-11-03	Confirmed
26	CISA and FBI, AA20-304A, Iranian APT actor identified obtaining voter registration data, 30 Oct 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-304a	2026-11-03	Confirmed
27	Microsoft On the Issues, Phosphorus attacks on Munich Security Conference and T20 invitees, 28 Oct 2020	https://blogs.microsoft.com/on-the-issues/2020/10/28/cyberattacks-phosphorus-t20-munich-security-conference/	2026-11-03	Confirmed
28	Check Point Research, Ransomware alert: Pay2Key, 6 Nov 2020	https://research.checkpoint.com/2020/ransomware-alert-pay2key/	2026-11-03	Confirmed
29	CISA, FBI, Treasury and USCYBERCOM, AA20-239A, FASTCash 2.0: North Korea's BeagleBoyz robbing banks, 26 Aug 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-239a	2026-11-03	Confirmed
30	CISA and FBI, AR20-232A, malware analysis of the BLINDINGCAN RAT, 19 Aug 2020	https://www.cisa.gov/news-events/analysis-reports/ar20-232a	2026-11-03	Confirmed
31	CISA, FBI and CNMF, AA20-301A, North Korean APT focus: Kimsuky, 27 Oct 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-301a	2026-11-03	Confirmed
32	FBI, wanted poster: Jon Chang Hyok	https://www.fbi.gov/wanted/cyber/jon-chang-hyok	2026-11-03	Confirmed
33	ESET WeLiveSecurity, Operation In(ter)ception: aerospace and military companies targeted by cyberspies, 17 Jun 2020	https://www.welivesecurity.com/2020/06/17/operation-interception-aerospace-military-companies-cyberspies/	2026-11-03	Confirmed
34	ESET WeLiveSecurity, Lazarus supply-chain attack in South Korea, 16 Nov 2020	https://www.welivesecurity.com/2020/11/16/lazarus-supply-chain-attack-south-korea/	2026-11-03	Confirmed
35	Kaspersky Securelist, MATA: multi-platform targeted malware framework, 22 Jul 2020	https://securelist.com/mata-multi-platform-targeted-malware-framework/97746/	2026-11-03	Confirmed
36	FireEye (Google Cloud blog), Unauthorized access of FireEye red team tools, 8 Dec 2020	https://cloud.google.com/blog/topics/threat-intelligence/unauthorized-access-of-fireeye-red-team-tools	2026-11-03	Confirmed
37	FireEye (Google Cloud blog), SUNBURST backdoor report on the SolarWinds supply-chain compromise, 13 Dec 2020	https://cloud.google.com/blog/topics/threat-intelligence/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor	2026-11-03	Confirmed
38	CISA, Emergency Directive 21-01, closed directive page	https://www.cisa.gov/news-events/directives/ed-21-01-mitigate-solarwinds-orion-code-compromise-closed	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
39	CISA, Emergency Directive 21-01, Mitigate SolarWinds Orion code compromise, 13 Dec 2020	https://www.cisa.gov/news-events/directives/ed-21-01-mitigate-solarwinds-orion-code-compromise	2026-11-03	Confirmed
40	CISA, AA20-352A, APT compromise of government agencies, critical infrastructure and private sector organizations, 17 Dec 2020, revised 15 Apr 2021	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a	2026-11-03	Confirmed
41	CISA and UK NCSC, AA20-099A, COVID-19 exploited by malicious cyber actors, 8 Apr 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-099a	2026-11-03	Confirmed
42	CISA and UK NCSC, AA20-126A, APT groups target healthcare and essential services, 5 May 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-126a	2026-11-03	Confirmed
43	CISA and FBI, AA20-336A, APT actors targeting U.S. think tanks, 1 Dec 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-336a	2026-11-03	Confirmed
44	ESET WeLiveSecurity, Operation Spalax: targeted malware attacks in Colombia, 12 Jan 2021	https://www.welivesecurity.com/2021/01/12/operation-spalax-targeted-malware-attacks-colombia/	2026-11-03	Confirmed
45	CISA, Known Exploited Vulnerabilities catalog, JSON feed (catalogVersion 2026.11.03)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-03	Confirmed
46	MITRE ATT&CK, software S0502 Drovorub	https://attack.mitre.org/software/S0502/	2026-11-03	Confirmed
47	Google Cloud blog, Protecting against cyber threats during COVID-19 and beyond, 16 Apr 2020	https://cloud.google.com/blog/products/identity-security/protecting-against-cyber-threats-during-covid-19-and-beyond	2026-11-03	Confirmed
48	Microsoft On the Issues, New action to combat ransomware ahead of U.S. elections (Trickbot), 12 Oct 2020	https://blogs.microsoft.com/on-the-issues/2020/10/12/trickbot-ransomware-cyberthreat-us-elections/	2026-11-03	Confirmed
49	Mandiant (Google Cloud blog), Tactics, techniques and procedures associated with Maze ransomware incidents	https://cloud.google.com/blog/topics/threat-intelligence/tactics-techniques-procedures-associated-with-maze-ransomware-incidents	2026-11-03	Confirmed
50	BleepingComputer, Maze ransomware shuts down operations, denies creating cartel, Nov 2020	https://www.bleepingcomputer.com/news/security/maze-ransomware-shuts-down-operations-denies-creating-cartel/	2026-11-03	Reported
51	US Treasury, sm845, sanctions on Evil Corp, 5 Dec 2019	https://home.treasury.gov/news/press-releases/sm845	2026-11-03	Confirmed
52	NCC Group and Fox-IT, WastedLocker: a new ransomware variant developed by the Evil Corp group, 23 Jun 2020	https://www.nccgroup.com/research/wastedlocker-a-new-ransomware-variant-developed-by-the-evil-corp-group/	2026-11-03	Confirmed
53	Symantec, WastedLocker ransomware targeting US organizations, 25 Jun 2020	https://www.security.com/threat-intelligence/wastedlocker-ransomware-us	2026-11-03	Confirmed
54	Garmin, Form 8-K exhibit 99.1 on the 23 Jul 2020 cyber attack (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1121788/000121390020018705/ea124587ex99-1_garmin.htm`	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
55	Treasury OFAC, recent actions of 1 Oct 2020: ransomware advisory	https://ofac.treasury.gov/recent-actions/20201001	2026-11-03	Confirmed
56	FTC, order requiring Blackbaud to delete unnecessary data and boost safeguards, Feb 2024	https://www.ftc.gov/news-events/news/press-releases/2024/02/ftc-order-will-require-blackbaud-delete-unnecessary-data-boost-safeguards-settle-charges-its-lax	2026-11-03	Confirmed
57	SEC, press release 2023-48, Blackbaud charged over misleading ransomware disclosures, 9 Mar 2023	https://www.sec.gov/news/press-release/2023-48	2026-11-03	Confirmed
58	FTC, final order with Blackbaud, May 2024	https://www.ftc.gov/news-events/news/press-releases/2024/05/ftc-finalizes-order-blackbaud-related-allegations-firms-security-failures-led-data-breach	2026-11-03	Confirmed
59	Yle News, Vastaamo patients receive extortion emails, Oct 2020	https://yle.fi/a/3-11612230	2026-11-03	Reported
60	Yle News, verdict in the Vastaamo case, 30 Apr 2024	https://yle.fi/a/74-20086499	2026-11-03	Reported
61	Universal Health Services, Form 10-K for 2020 (SEC EDGAR)	https://www.sec.gov/Archives/edgar/data/352915/000156459021008851/uhs-10k_20201231.htm	2026-11-03	Confirmed
62	Twitter, An update on our security incident, Jul 2020	https://blog.x.com/en_us/topics/company/2020/an-update-on-our-security-incident	2026-11-03	Confirmed
63	New York DFS, press release on the Twitter investigation report, 14 Oct 2020	https://www.dfs.ny.gov/reports_and_publications/press_releases/pr202010141	2026-11-03	Confirmed
64	US Secret Service, arrest in connection with the alleged role in the Twitter hack, 21 Jul 2021	https://www.secretservice.gov/newsroom/releases/2021/07/man-arrested-connection-alleged-role-twitter-hack	2026-11-03	Confirmed
65	CISA, AA20-280A, Emotet malware, 6 Oct 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-280a	2026-11-03	Confirmed
66	Microsoft On the Issues, An update on disruption of Trickbot, 20 Oct 2020	https://blogs.microsoft.com/on-the-issues/2020/10/20/trickbot-ransomware-disruption-update/	2026-11-03	Confirmed
67	Eurojust, Emotet disrupted through global action, 27 Jan 2021	https://www.eurojust.europa.eu/worlds-most-dangerous-malware-emotet-disrupted-through-global-action	2026-11-03	Confirmed
68	CISA, FBI and HHS, AA20-302A, Ransomware activity targeting the healthcare and public health sector, 28 Oct 2020, updated 2 Nov 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-302a	2026-11-03	Confirmed
69	Mandiant (Google Cloud blog), KEGTAP and SINGLEMALT with a ransomware chaser, 28 Oct 2020	https://cloud.google.com/blog/topics/threat-intelligence/kegtap-and-singlemalt-with-a-ransomware-chaser	2026-11-03	Confirmed
70	CISA, ED 20-02, Mitigate Windows vulnerabilities from January 2020 Patch Tuesday	https://www.cisa.gov/news-events/directives/ed-20-02-mitigate-windows-vulnerabilities-january-2020-patch-tuesday	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
71	CISA, Emergency Directive 20-02, alternate directive page	https://www.cisa.gov/news-events/directives/emergency-directive-20-02	2026-11-03	Confirmed
72	CISA, ED 20-03 text (PDF), Mitigate Windows DNS Server vulnerability, 16 Jul 2020	https://www.cisa.gov/sites/default/files/ed-20-03.pdf	2026-11-03	Confirmed
73	CISA alert, Emergency Directive on a critical Microsoft vulnerability, 16 Jul 2020	https://www.cisa.gov/news-events/alerts/2020/07/16/cisa-releases-emergency-directive-critical-microsoft-vulnerability	2026-11-03	Confirmed
74	CISA, Emergency Directive 20-03, directive page	https://www.cisa.gov/news-events/directives/emergency-directive-20-03	2026-11-03	Confirmed
75	CISA, ED 20-04, Mitigate Netlogon elevation of privilege vulnerability from August 2020 Patch Tuesday	https://www.cisa.gov/news-events/directives/ed-20-04-mitigate-netlogon-elevation-privilege-vulnerability-august-2020-patch-tuesday	2026-11-03	Confirmed
76	CISA, Emergency Directive 20-04, alternate directive page	https://www.cisa.gov/news-events/directives/emergency-directive-20-04	2026-11-03	Confirmed
77	CISA, BOD 20-01, Develop and publish a vulnerability disclosure policy, 2 Sep 2020	https://www.cisa.gov/news-events/directives/bod-20-01-develop-and-publish-vulnerability-disclosure-policy	2026-11-03	Confirmed
78	CISA, BOD 22-01, Reducing the significant risk of known exploited vulnerabilities, 3 Nov 2021	https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities	2026-11-03	Confirmed
79	Microsoft Security Response Center, update guide record for CVE-2020-1472 (API)	https://api.msrc.microsoft.com/sug/v2.0/en-US/vulnerability?$filter=cveNumber%20eq%20%27CVE-2020-1472%27	2026-11-03	Confirmed
80	NIST NVD, CVE-2020-1472 record (API 2.0)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2020-1472	2026-11-03	Confirmed
81	Microsoft Support, KB4557222, managing the Netlogon secure channel changes for CVE-2020-1472	https://support.microsoft.com/en-us/topic/how-to-manage-the-changes-in-netlogon-secure-channel-connections-associated-with-cve-2020-1472-f7e8cc17-0309-1d6a-304e-5ba73cd1a11e	2026-11-03	Confirmed
82	Secura (bvcyber), CVE-2020-1472 Zerologon tester repository	https://github.com/bvcyber/CVE-2020-1472	2026-11-03	Demonstrated
83	MSRC blog, Attacks exploiting Netlogon vulnerability (CVE-2020-1472), 29 Oct 2020	https://www.microsoft.com/en-us/msrc/blog/2020/10/attacks-exploiting-netlogon-vulnerability-cve-2020-1472	2026-11-03	Confirmed
84	CISA, ACSC, NCSC and FBI, AA21-209A, Top routinely exploited vulnerabilities, 28 Jul 2021	https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-209a	2026-11-03	Confirmed
85	CISA, AA20-020A, Critical vulnerability in Citrix ADC, Gateway and SD-WAN WANOP	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-020a	2026-11-03	Confirmed
86	FireEye (Google Cloud blog), Vigilante deploying mitigation for Citrix NetScaler vulnerability while maintaining backdoor, 15 Jan 2020	https://cloud.google.com/blog/topics/threat-intelligence/vigilante-deploying-mitigation-for-citrix-netscaler-vulnerability-while-maintaining-backdoor/	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
87	FireEye (Google Cloud blog), APT41 initiates global intrusion campaign using multiple exploits, 25 Mar 2020	https://cloud.google.com/blog/topics/threat-intelligence/apt41-initiates-global-intrusion-campaign-using-multiple-exploits/	2026-11-03	Confirmed
88	CISA, AA20-010A, Continued exploitation of Pulse Secure VPN vulnerability, 10 Jan 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-010a	2026-11-03	Confirmed
89	CISA, AA20-107A, Continued threat actor exploitation post Pulse Secure VPN patching, 16 Apr 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-107a	2026-11-03	Confirmed
90	CISA, AA20-133A, Top 10 routinely exploited vulnerabilities, 12 May 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-133a	2026-11-03	Confirmed
91	Microsoft Security Response Center, update guide record for CVE-2020-0796 (API)	https://api.msrc.microsoft.com/sug/v2.0/en-US/vulnerability?$filter=cveNumber%20eq%20%27CVE-2020-0796%27	2026-11-03	Confirmed
92	chompie1337, SMBGhost_RCE_PoC repository	https://github.com/chompie1337/SMBGhost_RCE_PoC	2026-11-03	Demonstrated
93	CISA alert, Unpatched Microsoft systems vulnerable to CVE-2020-0796, 5 Jun 2020	https://www.cisa.gov/news-events/alerts/2020/06/05/unpatched-microsoft-systems-vulnerable-cve-2020-0796	2026-11-03	Confirmed
94	CISA, AA20-206A, Threat actor exploitation of F5 BIG-IP CVE-2020-5902, 24 Jul 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-206a	2026-11-03	Confirmed
95	NIST NVD, CVE-2020-5902 record (API 2.0)	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2020-5902	2026-11-03	Confirmed
96	Palo Alto Networks, security advisory CVE-2020-2021, PAN-OS authentication bypass in SAML authentication, 29 Jun 2020	https://security.paloaltonetworks.com/CVE-2020-2021	2026-11-03	Confirmed
97	Oracle, Critical Patch Update advisory, October 2020	https://www.oracle.com/security-alerts/cpuoct2020.html	2026-11-03	Confirmed
98	SANS Internet Storm Center, diary 26734 on WebLogic CVE-2020-14882 exploitation, 29 Oct 2020	https://isc.sans.edu/diary/26734	2026-11-03	Confirmed
99	Oracle, Security Alert CVE-2020-14750, 1 Nov 2020	https://www.oracle.com/security-alerts/alert-cve-2020-14750.html	2026-11-03	Confirmed
100	CISA, AA20-195A, Critical vulnerability in SAP NetWeaver AS Java (RECON), 13 Jul 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-195a	2026-11-03	Confirmed
101	CISA, ICSA-20-168-01, Treck TCP/IP stack (Ripple20), 16 Jun 2020	https://www.cisa.gov/news-events/ics-advisories/icsa-20-168-01	2026-11-03	Confirmed
102	TeamStarWolf library data files (`data/attack`, `data/weaknesses`), main branch	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
103	SolarWinds, Form 8-K of 11 Jan 2021 with investigation update (SEC EDGAR)	https://www.sec.gov/Archives/edgar/data/1739942/000173994221000015/swi-20210111.htm	2026-11-03	Confirmed
104	SolarWinds, Form 8-K of 14 Dec 2020 (SEC EDGAR)	https://www.sec.gov/Archives/edgar/data/1739942/000162828020017451/swi-20201214.htm	2026-11-03	Confirmed
105	MSRC blog, Customer guidance on recent nation-state cyber attacks, Dec 2020	https://www.microsoft.com/en-us/msrc/blog/2020/12/customer-guidance-on-recent-nation-state-cyber-attacks	2026-11-03	Confirmed
106	Microsoft On the Issues, the need for a strong global cybersecurity response (Brad Smith), 17 Dec 2020	https://blogs.microsoft.com/on-the-issues/2020/12/17/cyberattacks-cybersecurity-solarwinds-fireeye/	2026-11-03	Confirmed
107	CrowdStrike, free tool to identify and help mitigate risks in Azure Active Directory, Dec 2020	https://www.crowdstrike.com/en-us/blog/crowdstrike-launches-free-tool-to-identify-and-help-mitigate-risks-in-azure-active-directory/	2026-11-03	Confirmed
108	MSRC blog, Microsoft internal Solorigate investigation update, 31 Dec 2020	https://www.microsoft.com/en-us/msrc/blog/2020/12/microsoft-internal-solorigate-investigation-update	2026-11-03	Confirmed
109	CISA, Joint statement by FBI, CISA, ODNI and NSA (Cyber Unified Coordination Group), 5 Jan 2021	https://www.cisa.gov/news-events/news/joint-statement-federal-bureau-investigation-fbi-cybersecurity-and-infrastructure-security-agency-0	2026-11-03	Confirmed
110	Mimecast, Form 8-K exhibit 99.1, 12 Jan 2021 (SEC EDGAR)	https://www.sec.gov/Archives/edgar/data/1644675/000119312521006829/d47544dex991.htm	2026-11-03	Confirmed
111	Mimecast, incident report exhibit 99.2, 16 Mar 2021 (SEC EDGAR)	https://www.sec.gov/Archives/edgar/data/1644675/000119312521082200/d141664dex992.htm	2026-11-03	Confirmed
112	The White House (archived), Fact sheet: imposing costs for harmful foreign activities by the Russian government, 15 Apr 2021	https://bidenwhitehouse.archives.gov/briefing-room/statements-releases/2021/04/15/fact-sheet-imposing-costs-for-harmful-foreign-activities-by-the-russian-government/	2026-11-03	Confirmed
113	SEC, press release 2024-174, four companies charged over misleading cyber disclosures, 22 Oct 2024	https://www.sec.gov/newsroom/press-releases/2024-174	2026-11-03	Confirmed
114	Marriott International, Form 10-Q for Q1 2020 (SEC EDGAR)	https://www.sec.gov/Archives/edgar/data/1048286/000162828020007376/mar-q12020x10q.htm	2026-11-03	Confirmed
115	FTC, action against Marriott and Starwood over data security failures, 9 Oct 2024	https://www.ftc.gov/node/86484	2026-11-03	Confirmed
116	Marriott International, Form 10-Q for Q3 2020 (SEC EDGAR)	https://www.sec.gov/Archives/edgar/data/1048286/000162828020015909/mar-20200930.htm	2026-11-03	Confirmed
117	easyJet plc, RNS Notice of cyber security incident, 19 May 2020 (Investegate republication of the RNS)	https://www.investegate.co.uk/announcement/rns/easyjet--ezj/notice-of-cyber-security-incident/6053711	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
118	MSRC blog, Access misconfiguration for customer support database, 22 Jan 2020	https://www.microsoft.com/en-us/msrc/blog/2020/01/access-misconfiguration-for-customer-support-database	2026-11-03	Confirmed
119	Comparitech, Microsoft customer service data leak, Jan 2020	https://www.comparitech.com/blog/information-security/microsoft-customer-service-data-leak/	2026-11-03	Reported
120	OCC, NR 2020-101, civil money penalty against Capital One, 6 Aug 2020	https://www.occ.gov/news-issuances/news-releases/2020/nr-occ-2020-101.html	2026-11-03	Confirmed
121	CISA, AR21-013A, Strengthening security configurations to defend against attackers targeting cloud services, 13 Jan 2021	https://www.cisa.gov/news-events/analysis-reports/ar21-013a	2026-11-03	Confirmed
122	TeamStarWolf library generated MITRE pages (`mitre/`), main branch	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre	2026-11-03	Confirmed
123	TeamStarWolf library, NOTABLE_INCIDENTS.md, main branch	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/NOTABLE_INCIDENTS.md	2026-11-03	Confirmed
124	CISA alert, NSA advisory on Sandworm actors exploiting the Exim vulnerability, 28 May 2020	https://www.cisa.gov/news-events/alerts/2020/05/28/nsa-releases-advisory-sandworm-actors-exploiting-exim-vulnerability	2026-11-03	Confirmed
125	NSA and CISA, AA20-205A, immediate actions to reduce exposure across operational technologies and control systems, 23 Jul 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-205a	2026-11-03	Confirmed
126	MITRE ATT&CK, group G0034 Sandworm Team	https://attack.mitre.org/groups/G0034/	2026-11-03	Confirmed
127	CISA alert, NSA advisory on Chinese state-sponsored actors exploiting known vulnerabilities, 20 Oct 2020	https://cisa.gov/news-events/alerts/2020/10/20/nsa-releases-advisory-chinese-state-sponsored-actors-exploiting	2026-11-03	Confirmed
128	FBI, CISA and MS-ISAC, AA20-345A, Cyber actors target K-12 distance learning education, 10 Dec 2020	https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-345a	2026-11-03	Confirmed
129	MITRE ATT&CK, campaign C0024 SolarWinds Compromise	https://attack.mitre.org/campaigns/C0024/	2026-11-03	Confirmed
130	MITRE ATT&CK, software S0514 WellMess	https://attack.mitre.org/software/S0514/	2026-11-03	Confirmed
131	MITRE ATT&CK, software S0446 Ryuk	https://attack.mitre.org/software/S0446/	2026-11-03	Confirmed
132	MITRE ATT&CK, Updates July 2020 (v7)	https://attack.mitre.org/resources/updates/updates-july-2020/	2026-11-03	Confirmed
133	MITRE ATT&CK, Updates October 2020 (v8)	https://attack.mitre.org/resources/updates/updates-october-2020/	2026-11-03	Confirmed
134	Red Canary, 2021 Threat Detection Report (2020 data), PDF	https://resource.redcanary.com/rs/003-YRU-314/images/2021-Threat-Detection-Report.pdf	2026-11-03	Confirmed
135	CISA and MS-ISAC, Ransomware Guide	https://www.cisa.gov/stopransomware/ransomware-guide	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
136	Federal Register (GovInfo PDF), Executive Order 14028, Improving the Nation's Cybersecurity, 17 May 2021	https://www.govinfo.gov/content/pkg/FR-2021-05-17/pdf/2021-10460.pdf	2026-11-03	Confirmed
137	TeamStarWolf library repository, main branch (`mitre/` tree and the Navigator validator)	https://github.com/TeamStarWolf/TeamStarWolf	2026-11-03	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- Home studies: SolarWinds and SUNBURST, 2019 to 2021; APT41: the public record
- Groups: G0034 Sandworm Team, G0007 APT28, G0016 APT29, G0035 Dragonfly, G0096 APT41, G0117 Fox Kitten, G0059 Magic Hound, G0032 Lazarus Group, G0082 APT38, G0094 Kimsuky, G0102 Wizard Spider, G0119 Indrik Spider
- Software: S0559 SUNBURST, S0502 Drovorub, S0514 WellMess, S0446 Ryuk, S0266 TrickBot, S0367 Emotet, S0449 Maze, S0612 WastedLocker, S0154 Cobalt Strike
- Campaigns: C0024 SolarWinds Compromise, C0022 Operation Dream Job, C0005 Operation Spalax
- Techniques: T1190, T1133, T1078.002, T1110.003, T1195.002, T1606.002, T1486, T1490
- Navigator layers, including this study's layers, chronicle-2020.json and chronicle-2020-ics.json